Contents

1 Manage a security operations environment (40–45%) 10

1.1 Configure automation for Microsoft Defender XDR and Microsoft Sentinel . . . 10

1.1.1 Configure email notifications in Microsoft Defender XDR, including incidents, actions, and threat analytics . . . 10

1.1.1.1 Incident notifications . . . 10

1.1.1.2 Action notifications . . . 11

1.1.1.3 Threat analytics notifications . . . 12

1.1.1.4 Permisos . . . 12

1.1.2 Configure alert notifications in Microsoft Defender XDR, including tuning, suppression, and correlation . . . 12

1.1.2.1 Alert notifications . . . 13

1.1.2.2 Permisos y RBAC . . . 13

1.1.2.3 Alert tuning . . . 13

1.1.2.4 Acciones de Alert tuning . . . 14

1.1.2.5 Built-in alert tuning rules . . . 15

1.1.2.6 Suppression . . . 16

1.1.2.7 Alert correlation . . . 16

1.1.2.8 Cross-product correlation . . . 17

1.1.2.9 Correlation with Microsoft Sentinel . . . 17

1.1.2.10 Incident merging . . . 17

1.1.2.11 Correlación manual . . . 18

1.1.2.12 Alert tuning vs. Allow indicator . . . 18

1.1.2.13 Escenarios típicos de examen . . . 18

1.1.3 Configure Microsoft Defender for Endpoint advanced features 19

1.1.3.1 EDR in block mode . . . 19

1.1.3.2 Tamper protection . . . 20

1.1.3.3 Allow or block file . . . 20

1.1.3.4 Custom network indicators . . . 21

1.1.3.5 Automatically resolve alerts . . . 21

1.1.3.6 Restrict correlation to within scoped device groups 22

1.1.3.7 Device discovery . . . 22

1.1.3.8 Live Response . . . 23

1.1.3.9 Unsigned scripts in Live Response . . . 23

1.1.3.10 Automatic attack disruption . . . 24

1.1.3.11 Microsoft Intune connection . . . 24

1.1.3.12 Microsoft Defender for Cloud Apps integration . 24

1.1.3.13 Web content filtering . . . 25

1.1.3.14 Unified audit log . . . 25

1.1.3.15 Share endpoint alerts with Microsoft Purview . . 25

1.1.3.16 Hide potential duplicate device records . . . 25

1.1.3.17 Download quarantined files . . . 26

1.1.3.18 Authenticated telemetry . . . 26
1.1.3.19 Streamlined connectivity . . . 26
1.1.3.20 Preview features . . . 26
1.1.3.21 Endpoint Attack Notifications . . . 27
1.1.3.22 Resumen de las funcionalidades más importantes 27
1.1.4 Configure rules settings in Microsoft Defender for Endpoint 28
1.1.4.1 Indicators . . . 28
1.1.4.2 File indicators . . . 28
1.1.4.3 IP, URL and domain indicators . . . 29
1.1.4.4 Allow indicators . . . 29
1.1.4.5 Multiple Web Content Filtering policies . . . 29
1.1.4.6 Automation uploads . . . 30
1.1.4.7 Automation folder exclusions . . . 30
1.1.4.8 Automation folder exclusions and AIR . . . 31
1.1.5 Configure custom data collection in Microsoft Defender for Endpoint . . . 31
1.1.5.1 Cuándo utilizar Custom Data Collection . . . 31
1.1.5.2 Flujo de funcionamiento . . . 31
1.1.5.3 Ruta de configuración . . . 32
1.1.5.4 Requisitos previos . . . 33
1.1.5.5 Dynamic tags . . . 33
1.1.5.6 Creación de una regla . . . 34
1.1.5.7 Supported event tables . . . 34
1.1.5.8 DeviceCustomProcessEvents . . . 34
1.1.5.9 DeviceCustomImageLoadEvents . . . 34
1.1.5.10 DeviceCustomFileEvents . . . 35
1.1.5.11 DeviceCustomNetworkEvents . . . 35
1.1.5.12 DeviceCustomScriptEvents . . . 35
1.1.5.13 Conditions . . . 35
1.1.5.14 Scope . . . 35
1.1.5.15 Deployment time . . . 35
1.1.5.16 Límite de eventos . . . 36
1.1.5.17 Consultar los datos . . . 36
1.1.5.18 Monitorización y troubleshooting . . . 36
1.1.5.19 Enable, disable and delete . . . 37
1.1.5.20 Escenarios típicos de examen . . . 37
1.1.6 Configure security policies for Microsoft Defender for Endpoint, including attack surface reduction (ASR) rules . . . 38
1.1.6.1 Tipos de Endpoint security policies . . . 38
1.1.6.2 Security Settings Management . . . 39
1.1.6.3 Intune enrolled vs. MDE managed . . . 40
1.1.6.4 Creación de una Endpoint security policy . . . 40
1.1.6.5 Assignments . . . 41
1.1.6.6 Policy deployment . . . 41
1.1.6.7 Attack Surface Reduction . . . 41
1.1.6.8 Qué son las ASR rules . . . 42

1.1.6.9 Requisitos de ASR . . . 42
1.1.6.10 Sistemas operativos . . . 43
1.1.6.11 Modos de las ASR rules . . . 43
1.1.6.12 Audit mode . . . 43
1.1.6.13 Block mode . . . 43
1.1.6.14 Warn mode . . . 44
1.1.6.15 Standard protection rules . . . 44
1.1.6.16 Block abuse of exploited vulnerable signed drivers 44
1.1.6.17 Block credential stealing from LSASS . . . 44
1.1.6.18 Block persistence through WMI event subscription 45
1.1.6.19 Otras ASR rules importantes . . . 45
1.1.6.20 Cloud-delivered protection . . . 46
1.1.6.21 ASR exclusions . . . 46
1.1.6.22 Exclusiones y seguridad . . . 47
1.1.6.23 Controlled Folder Access . . . 47
1.1.6.24 Despliegue recomendado de ASR . . . 48
1.1.6.25 Escenarios típicos de examen . . . 48
1.1.7 Manage automated investigation and response capabilities in Microsoft Defender XDR . . . 49
1.1.7.1 Funcionamiento de AIR . . . 50
1.1.7.2 Verdicts . . . 50
1.1.7.3 Remediation actions . . . 51
1.1.7.4 Automation levels en Defender for Endpoint . . 52
1.1.7.5 Semi automation . . . 53
1.1.7.6 Suspicious evidence . . . 53
1.1.7.7 No threats found . . . 53
1.1.7.8 Action Center . . . 53
1.1.7.9 Approve and Reject . . . 54
1.1.7.10 Undo remediation actions . . . 55
1.1.7.11 Action source . . . 55
1.1.7.12 Permisos . . . 56
1.1.7.13 Escenarios típicos de examen . . . 56
1.1.8 Configure automatic attack disruption in Microsoft Defender XDR . . . 57
1.1.8.1 Acciones automáticas principales . . . 57
1.1.8.2 Contain device . . . 58
1.1.8.3 Automatic device isolation . . . 58
1.1.8.4 Contain user . . . 59
1.1.8.5 Disable user . . . 59
1.1.8.6 Estado de Microsoft Defender Antivirus . . . 59
1.1.8.7 Requisitos de Defender for Identity . . . 60
1.1.8.8 Requisitos de Defender for Cloud Apps . . . 60
1.1.8.9 Requisitos de Defender for Office 365 . . . 60
1.1.8.10 Exclusiones de Automatic Attack Disruption . . 61
1.1.8.11 User exclusions . . . 61
1.1.8.12 Device group exclusions . . . 61

1.1.8.13 Policy application exclusions 62
1.1.8.14 Cómo identificar que se ha producido Attack Disruption 62
1.1.8.15 Reversión de las acciones 62
1.1.8.16 Advanced Hunting 62
1.1.8.17 Escenarios típicos de examen 63
1.1.9 Configure and manage device groups, permissions, and automation levels in Microsoft Defender for Endpoint . . 64
1.1.9.1 Creación de un device group 64
1.1.9.2 Device matching rules 65
1.1.9.3 Preview devices 66
1.1.9.4 Device group ranking 66
1.1.9.5 Promote and demote 67
1.1.9.6 Ungrouped devices 67
1.1.9.7 Número máximo de grupos 67
1.1.9.8 User access 67
1.1.9.9 Device group sin User Access 68
1.1.9.10 Unified RBAC 68
1.1.9.11 Permisos importantes en Unified RBAC 68
1.1.9.12 Principio de mínimo privilegio 69
1.1.9.13 Ejemplo de RBAC 69
1.1.9.14 Automation levels 69
1.1.9.15 Device groups y alertas 70
1.1.9.16 Device groups y email notifications 70
1.1.9.17 Device groups vs. Device tags 70
1.1.9.18 Device groups vs. Microsoft Entra groups 70
1.1.9.19 Escenarios típicos de examen 71
1.1.10 Create and configure automation rules in Microsoft Sentinel 72
1.1.10.1 Creación de una Automation Rule 73
1.1.10.2 Triggers 73
1.1.10.3 Conditions 73
1.1.10.4 Operadores 74
1.1.10.5 Updated by 74
1.1.10.6 Actions 75
1.1.10.7 Change status 75
1.1.10.8 Change severity 75
1.1.10.9 Assign owner 75
1.1.10.10 Add tag 76
1.1.10.11 Add task 76
1.1.10.12 Run playbook 76
1.1.10.13 Compatibilidad de triggers con playbooks 77
1.1.10.14 Automation Rule vs. Playbook 77
1.1.10.15 Order de las Automation Rules 77
1.1.10.16 Orden por tipo de trigger 78
1.1.10.17 Rule expiration 78
1.1.10.18 Crear Automation Rules desde Analytics 78

1.1.10.19 Reglas habilitadas y deshabilitadas 79
1.1.10.20 Escenarios típicos de examen 79
1.1.11 Create and configure Microsoft Sentinel playbooks 80
1.1.11.1 Ruta de creación 80
1.1.11.2 Azure Logic Apps 80
1.1.11.3 Tipos de Logic App 81
1.1.11.4 Consumption playbooks 81
1.1.11.5 Standard playbooks 82
1.1.11.6 Limitaciones de Standard 82
1.1.11.7 Triggers 83
1.1.11.8 Incident trigger 83
1.1.11.9 Alert trigger 83
1.1.11.10 Entity trigger 84
1.1.11.11 Entity types 84
1.1.11.12 Acciones principales del Microsoft Sentinel connector 84
1.1.11.13 Update Incident 85
1.1.11.14 Add comments to incident 85
1.1.11.15 Dynamic content 85
1.1.11.16 Expressions 86
1.1.11.17 Control flow 86
1.1.11.18 For each 87
1.1.11.19 Connectors 87
1.1.11.20 Autenticación 88
1.1.11.21 Playbook templates 88
1.1.11.22 Casos de uso de playbooks 89
1.1.11.23 Monitorización del playbook 89
1.1.11.24 Problemas habituales 90
1.1.11.25 Escenarios típicos de examen 90
1.2 Configure the Microsoft Sentinel SIEM and platform 92
1.2.1 Specify Microsoft Sentinel roles 92
1.2.1.1 Microsoft Sentinel Reader 92
1.2.1.2 Microsoft Sentinel Responder 93
1.2.1.3 Microsoft Sentinel Contributor 94
1.2.1.4 Jerarquía fundamental 94
1.2.1.5 Microsoft Sentinel Playbook Operator 95
1.2.1.6 Microsoft Sentinel Automation Contributor . . . 95
1.2.1.7 Playbook Operator vs. Automation Contributor 96
1.2.1.8 Permisos para ejecutar manualmente un playbook sobre un incidente 96
1.2.1.9 Contributor no permite crear playbooks 96
1.2.1.10 Workbooks 97
1.2.1.11 Data connectors 97
1.2.1.12 Content Hub 97
1.2.1.13 Scope de los roles 98
1.2.1.14 Azure roles generales 98
1.2.1.15 Roles de Log Analytics 99

1.2.1.16 Microsoft Sentinel Data Lake 99
1.2.1.17 Resumen de roles 99
1.2.1.18 Escenarios típicos de examen 100
1.2.2 Manage data retention for XDR and Microsoft Sentinel tables, including Analytics, Data lake, and XDR tiers . . 101
1.2.2.1 Comparación fundamental 101
1.2.2.2 XDR default tier 101
1.2.2.3 Extender la retención de XDR 102
1.2.2.4 Analytics tier 102
1.2.2.5 Analytics retention vs. Total retention 103
1.2.2.6 Limitación fundamental del Data Lake 103
1.2.2.7 Consultar datos del Data Lake 103
1.2.2.8 Escenarios típicos de examen 104
1.2.3 Create and configure Microsoft Sentinel workbooks 104
1.2.3.1 Ruta 105
1.2.3.2 Workbook template vs. Workbook 105
1.2.3.3 Required data types 105
1.2.3.4 Crear un workbook desde cero 106
1.2.3.5 Queries 106
1.2.3.6 Visualizations 106
1.2.3.7 Parameters 107
1.2.3.8 Time range parameter 107
1.2.3.9 Guardar un workbook 108
1.2.3.10 Advanced Editor 108
1.2.3.11 Workbooks y Content Hub 108
1.2.3.12 Escenarios típicos de examen 109
1.2.4 Optimize the Microsoft Sentinel platform, including SOC optimization recommendations 109
1.2.4.1 Acceso 110
1.2.4.2 Tipos de recomendaciones 110
1.2.4.3 Excepción importante 110
1.2.4.4 Unused columns 111
1.2.4.5 Threat-based coverage recommendations 111
1.2.4.6 Similar organizations 112
1.2.4.7 Estados 112
1.2.4.8 Optimización de costes 113
1.2.4.9 SOC optimization vs. Analytics rule tuning . . . 113
1.2.4.10 Escenarios típicos de examen 113
1.3 Ingest data into the Microsoft Sentinel SIEM and platform . . . 115
1.3.1 Select data connectors based on data source requirements, including Windows logs and security events 115
1.3.1.1 Selección del conector 116
1.3.1.2 Windows Security Events via AMA 116
1.3.1.3 Data Collection Rules 117
1.3.1.4 Windows Security Event sets 117
1.3.1.5 Event IDs importantes 118

1.3.1.6 Equipos fuera de Azure . . . 118
1.3.1.7 Windows Event Forwarding . . . 118
1.3.1.8 Cuándo elegir AMA directo o WEF . . . 119
1.3.1.9 CEF via AMA . . . 120
1.3.1.10 Conectores API/service-to-service . . . 120
1.3.1.11 Custom connectors . . . 121
1.3.1.12 Escenarios típicos de examen . . . 121
1.3.2 Configure collection of Windows Security events by using Windows Security Events via AMA, including data collection rules . . . 122
1.3.2.1 Creación de la DCR . . . 122
1.3.2.2 Seleccionar los eventos . . . 123
1.3.2.3 Common vs. Minimal . . . 123
1.3.2.4 Custom collection . . . 124
1.3.2.5 Sintaxis XPath . . . 124
1.3.2.6 Límites de expresiones XPath . . . 125
1.3.2.7 Escenarios típicos de examen . . . 125
1.3.3 Plan and configure collection of Windows Security events by using Windows Event Forwarding (WEF) . . . 126
1.3.3.1 Tipos de suscripción . . . 126
1.3.3.2 Configuración del WEC . . . 127
1.3.3.3 Configuración de los clientes Source-initiated . . . 127
1.3.3.4 Forwarding del Security Log . . . 128
1.3.3.5 Subscription filter . . . 128
1.3.3.6 Equipos fuera del dominio . . . 128
1.3.3.7 Validación y troubleshooting . . . 129
1.3.4 Plan and configure Syslog via AMA and Common Event Format (CEF) via AMA connectors . . . 129
1.3.4.1 Arquitectura . . . 130
1.3.4.2 Configuración . . . 130
1.3.4.3 CEF . . . 131
1.3.4.4 Evitar duplicados . . . 132
1.3.4.5 Escenarios típicos de examen . . . 132
1.3.5 Configure collection of Azure activity logs by using Azure Policy and resource diagnostic settings . . . 132
1.3.5.1 Azure Activity Log . . . 132
1.3.5.2 Configuración desde Microsoft Sentinel . . . 133
1.3.5.3 Categorías del Activity Log . . . 134
1.3.5.4 Resource diagnostic settings . . . 134
1.3.5.5 Destinos posibles . . . 135
1.3.5.6 Tabla de destino . . . 135
1.3.5.7 Azure Policy . . . 135
1.3.5.8 Recursos nuevos y existentes . . . 136
1.3.5.9 Managed Identity . . . 136
1.3.5.10 Category groups . . . 136
1.3.5.11 Escenarios típicos de examen . . . 137

1.3.6 Ingest threat indicators into Microsoft Sentinel 137
1.3.6.1 Threat Intelligence – TAXII 137
1.3.6.2 STIX vs. TAXII 138
1.3.6.3 Defender Threat Intelligence 138
1.3.6.4 Creación manual 138
1.3.6.5 Ingestion rules 139
1.3.6.6 Uso posterior 139
1.3.7 Create custom log tables in the workspace to store ingested data 139
1.3.7.1 Creación 139
1.3.7.2 Nombre 140
1.3.7.3 Esquema 140
1.3.7.4 Table plan 141
1.3.7.5 Relación con la DCR 141
1.3.7.6 Transformation 142
1.3.7.7 Logs Ingestion API 142
1.3.7.8 Consulta 143
1.3.7.9 Escenarios típicos de examen 143
1.4 Configure detections 144
1.4.1 Create custom detection rules by using Advanced Hunting in Microsoft Defender XDR 144
1.4.1.1 Creación 144
1.4.1.2 Entity mapping 145
1.4.1.3 Alert details 145
1.4.1.4 Frecuencia 146
1.4.1.5 Continuous (NRT) 146
1.4.1.6 No filtrar innecesariamente por Timestamp . . . 147
1.4.1.7 Rule scope 147
1.4.1.8 Límite de alertas 147
1.4.1.9 Gestión 148
1.4.1.10 Custom Detection vs. Analytics Rule 148
1.4.1.11 Permisos 148
1.4.1.12 Escenarios típicos de examen 149
1.4.2 Manage custom detection rules in Microsoft Defender XDR 149
1.4.2.1 Información de ejecución 150
1.4.2.2 Rule details 150
1.4.2.3 Triggered alerts 150
1.4.2.4 Reglas de Sentinel en el portal unificado 151
1.4.2.5 Escenarios típicos de examen 151
1.4.3 Configure and manage analytics rules in Microsoft Sentinel SIEM, including scheduled, near-real time (NRT), threat intelligence, and machine learning 152
1.4.3.1 Tipos principales 152
1.4.3.2 Scheduled analytics rules 152
1.4.3.3 Trigger threshold 153
1.4.3.4 Ingestion delay 153

1.4.3.5 Alert enrichment . . . 154
1.4.3.6 Alert grouping . . . 154
1.4.3.7 Event grouping vs. Incident grouping . . . 154
1.4.3.8 NRT analytics rules . . . 155
1.4.3.9 NRT y latencia . . . 155
1.4.3.10 Threat Intelligence analytics rules . . . 155
1.4.3.11 Machine Learning analytics rules . . . 155
1.4.3.12 ML Behavior Analytics . . . 156
1.4.3.13 Fusion . . . 156
1.4.3.14 Cambio actual de Fusion . . . 157
1.4.3.15 Anomaly rules . . . 157
1.4.3.16 Required data sources . . . 158
1.4.4 Analyze attack vector coverage by using the MITRE ATT&CK matrix . . . 158
1.4.4.1 Tactics, techniques y sub-techniques . . . 158
1.4.4.2 Active coverage vs. Simulated coverage . . . 159
1.4.4.3 Identificar coverage gaps . . . 159
1.4.5 Configure anomalies in Microsoft Sentinel . . . 160
1.4.5.1 Propiedades de una anomaly rule . . . 160
1.4.5.2 Built-in rules . . . 161
1.4.5.3 Tuning . . . 161
1.4.5.4 Production vs. Flighting . . . 161
1.4.5.5 UEBA vs. ML anomalies . . . 162
1.4.5.6 Escenarios típicos de examen . . . 162

1 Manage a security operations environment (40–45%)

1.1 Configure automation for Microsoft Defender XDR and Microsoft Sentinel

1.1.1 Configure email notifications in Microsoft Defender XDR, including incidents, actions, and threat analytics

Microsoft Defender XDR permite crear **reglas de notificación por correo electrónico** para avisar al equipo SOC de determinados eventos. Las tres categorías principales que deben conocerse para el examen son:

- **Incidents**: creación o actualización de incidentes.
- **Actions**: resultado de acciones de respuesta manuales o automáticas.
- **Threat analytics**: publicación o actualización de informes de amenazas.

La configuración se realiza en:

Microsoft Defender portal → Settings → Microsoft Defender XDR → Email notifications

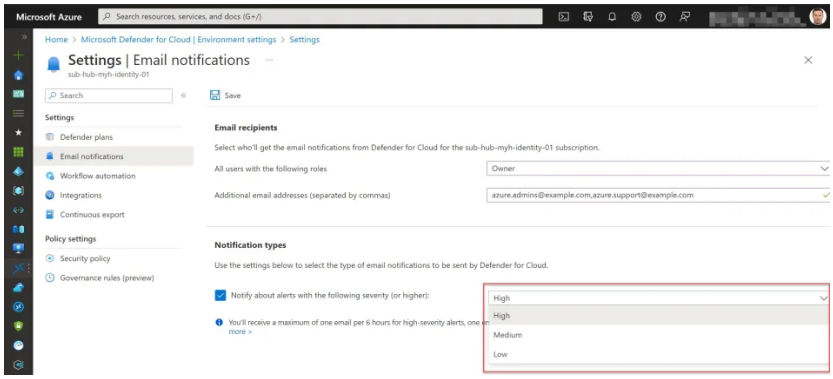


Figure 1: Caption

Desde aquí existen pestañas independientes para **Incidents**, **Actions** y **Threat analytics**.

1.1.1.1 Incident notifications

Permiten notificar al SOC cuando se crea un nuevo incidente o cuando se actualiza uno existente. Una regla puede filtrar las notificaciones principalmente en función de:

- **Severity**: severidad de las alertas asociadas al incidente.

- **Alert/service source**: servicio de Microsoft Defender que originó la detección.
- **Detection source**: permite mayor granularidad seleccionando determinados mecanismos de detección.
- **Device group scope**: todos los grupos de dispositivos o únicamente determinados grupos.

También puede configurarse:

- **Send only one notification per incident**: evita recibir múltiples correos por actualizaciones del mismo incidente.
- inclusión del **nombre de la organización**;
- inclusión de un **tenant-specific portal link**;
- uno o varios **recipients**;
- envío de un **test email** antes de guardar la regla.

El correo contiene información como el **nombre, severidad y categorías del incidente**, además de un enlace directo al incidente en Microsoft Defender para comenzar su investigación.

1.1.1.2 Action notifications

Permiten recibir notificaciones sobre las **response actions** ejecutadas dentro de Microsoft Defender XDR.

Las acciones pueden tener dos orígenes:

- **Manual**: ejecutadas directamente por un analista.
- **Automated**: ejecutadas automáticamente por Microsoft Defender, por ejemplo mediante *Automated Investigation and Response (AIR)* o *Automatic Attack Disruption*.

Al crear una regla pueden seleccionarse:

- **Action source**: manual, automated o ambas.
- **Action**: acciones concretas sobre las que se desea recibir notificación.
- **Device group scope**: grupos de dispositivos afectados.
- **Action status**: por ejemplo, acción **completed** o **failed**.
- **Recipients**: destinatarios de los correos.

Por tanto, una pregunta típica puede plantear que el SOC quiere ser avisado solamente cuando una **acción automática falle**. La solución sería una regla de **Actions email notifications** configurada con:

Action source = Automated
Action status = Failed

El correo proporciona acceso directo a la acción correspondiente para que el analista pueda revisarla.

1.1.1.3 Threat analytics notifications

Threat analytics proporciona informes elaborados a partir de la inteligencia e investigación de amenazas de Microsoft sobre campañas, actores, malware, vulnerabilidades y nuevas técnicas de ataque.

Las notificaciones permiten avisar cuando:

- se publica un **nuevo Threat analytics report**;
- se **actualiza un informe existente**.

La regla puede configurarse para recibir notificaciones sobre:

- **todos los informes**;
- determinados **report types**;
- informes asociados a determinados **tags**, por ejemplo *Ransomware*.

También se definen los destinatarios y puede utilizarse **Send test email** para comprobar la configuración.

1.1.1.4 Permisos

Para configurar las notificaciones se necesita el permiso:

Manage security settings

Con el modelo básico de permisos, normalmente se requiere **Security Administrator** o un rol superior.

Cuando se utiliza **RBAC**, un administrador solamente puede crear, modificar, eliminar y recibir determinadas notificaciones dentro del **scope de device groups** que puede administrar.

1.1.2 Configure alert notifications in Microsoft Defender XDR, including tuning, suppression, and correlation

Microsoft Defender XDR centraliza las alertas procedentes de servicios como **Defender for Endpoint, Defender for Identity, Defender for Office 365, Defender for Cloud Apps, Microsoft Entra ID Protection, Defender for Cloud y Microsoft Sentinel**. Una alerta representa una **detección individual de actividad potencialmente maliciosa**, mientras que un incidente agrupa alertas relacionadas para representar una historia de ataque completa.

Para el examen deben distinguirse cuatro conceptos:

- **Alert notification**: envío de una notificación cuando se genera una alerta.
- **Alert tuning**: reducción del ruido generado por actividad conocida o esperada.
- **Suppression**: ocultación automática de determinadas alertas; actualmente está integrada dentro de *Alert tuning*.
- **Correlation**: agrupación automática de alertas relacionadas dentro de incidentes.

1.1.2.1 Alert notifications

Microsoft Defender XDR permite crear reglas para enviar un **correo electrónico cuando se genera una nueva alerta**. Visto en el apartado anterior.

Se configuran desde:

> **Settings → Endpoints → General → Email notifications**

1.1.2.2 Permisos y RBAC

Para configurar las notificaciones se necesita el permiso:

> **Manage security settings**

Cuando se utiliza RBAC, el ámbito de la regla está condicionado por los **device groups** que puede administrar el usuario.

Por tanto:

> **RBAC + device groups → determinan sobre qué dispositivos puede configurar y recibir notificaciones un usuario.**

1.1.2.3 Alert tuning

Una de las funciones más importantes para SC-200 es **Alert tuning**, anteriormente denominada **Alert suppression**.

Su objetivo es reducir el **alert fatigue** evitando que actividades legítimas, conocidas o esperadas generen constantemente alertas que deben ser revisadas por el SOC.

Las reglas se administran desde:

> **Settings → Microsoft Defender XDR → Alert tuning**

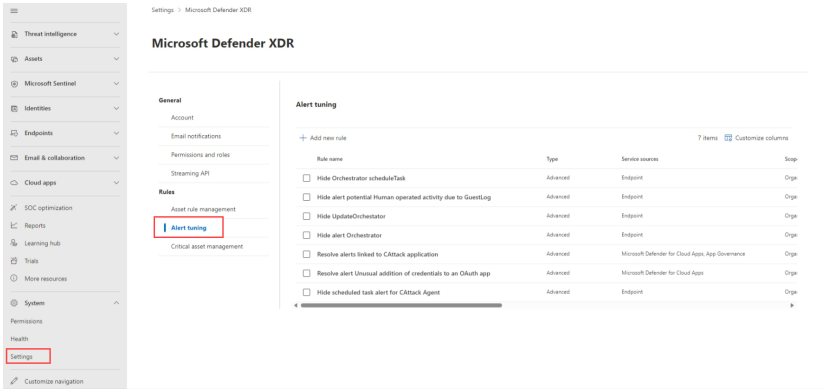


Figure 2: Caption

También puede crearse una regla directamente desde una alerta mediante:

Alert → Tune alert

Las reglas pueden basarse en evidencias relacionadas con la alerta, por ejemplo:

- archivos;
- procesos;
- scripts;
- eventos WMI;
- tareas programadas;
- otros indicadores o entidades asociados a la detección.

Se pueden combinar varias condiciones utilizando operadores:

AND, OR y agrupaciones de condiciones

Por ejemplo, si una herramienta corporativa legítima ejecuta habitualmente un determinado proceso que genera una alerta, puede crearse una regla para ajustar únicamente las alertas donde coincidan ese proceso y otras características concretas.

1.1.2.4 Acciones de Alert tuning

Una regla de *Alert tuning* puede ejecutar principalmente tres acciones:

1. **Hide alert**
2. **Resolve alert**
3. **Set as behavior**

Hide alert **Hide alert** suprime la alerta y evita que genere un incidente.

Sin embargo, los datos de la alerta **no desaparecen**. Continúan disponibles para *Advanced Hunting* en tablas como:

```
AlertInfo
AlertEvidence
```

Esta opción está disponible específicamente para alertas de **Microsoft Defender for Endpoint**.

Resolve alert **Resolve alert** permite que la alerta se genere, pero la marca automáticamente como **Resolved** cuando cumple las condiciones definidas.

También puede resolverse automáticamente el incidente relacionado.

Set as behavior **Set as behavior** convierte las señales coincidentes en **behaviors** en lugar de alertas.

Por tanto:

- no aparecen en la cola de alertas;
- no crean incidentes;
- siguen estando disponibles para investigación mediante Advanced Hunting.

Los datos pueden encontrarse en:

```
BehaviorInfo
BehaviorEntities
```

Esta opción no está soportada para determinadas fuentes, entre ellas **Defender for Cloud** y **Defender for Office 365**.

1.1.2.5 Built-in alert tuning rules

Microsoft Defender XDR incluye reglas de ajuste integradas para reducir automáticamente alertas generadas por actividades benignas habituales.

Un detalle importante para el examen es que la supresión de la alerta **no necesariamente detiene otros mecanismos de seguridad**.

Por ejemplo:

> Una alerta puede estar suprimida, pero una investigación de **Automated Investigation and Response (AIR)** puede continuar.

Si AIR determina posteriormente que existe actividad maliciosa o sospechosa, Defender puede **reactivar la alerta**.

Las reglas integradas de tuning no se aplican a:

- alertas generadas por **custom detection rules**;
- determinados indicadores de **Custom Threat Intelligence**.

En las **custom detections**, el analista debe modificar la propia lógica de detección para reducir los falsos positivos.

1.1.2.6 Suppression

Microsoft utiliza actualmente el concepto **Alert tuning** para la funcionalidad que anteriormente se denominaba **Alert suppression**.

Por tanto, si una pregunta del examen utiliza cualquiera de los dos términos:

> **Alert suppression ≈ funcionalidad actualmente denominada Alert tuning.**

1.1.2.7 Alert correlation

Microsoft Defender XDR utiliza un motor de **correlación automática** para determinar si diferentes alertas pertenecen al mismo ataque.

El funcionamiento básico es:

> **Security signals → Alerts → Correlation → Incidents**

Si una nueva alerta es suficientemente distinta de las existentes:

> **Nueva alerta → nuevo incidente**

Si está suficientemente relacionada con alertas existentes:

> **Nueva alerta → incidente existente**

La correlación puede considerar relaciones entre:

- dispositivos;
- usuarios;
- identidades;
- direcciones IP;
- archivos;
- procesos;
- buzones;
- aplicaciones;
- otras entidades y comportamientos asociados al ataque.

La lógica concreta utilizada para determinar la correlación es **propietaria de Microsoft**.

1.1.2.8 Cross-product correlation

Una característica fundamental de Microsoft Defender XDR es que puede correlacionar alertas procedentes de **diferentes productos de seguridad**.

Por ejemplo:

Defender for Office 365 detecta un correo de phishing

⇓

Defender for Identity detecta actividad anómala de la identidad

⇓

Defender for Endpoint detecta ejecución maliciosa en el dispositivo

⇓

Microsoft Defender XDR correlaciona las alertas en un único incidente.

Ésta es precisamente una de las funciones principales de una plataforma **XDR**: correlacionar telemetría y detecciones procedentes de diferentes dominios de seguridad.

1.1.2.9 Correlation with Microsoft Sentinel

Cuando Microsoft Sentinel está conectado al portal de Microsoft Defender, las alertas de Sentinel pueden participar también en la correlación.

Si existen varios workspaces de Sentinel:

- puede definirse un **primary workspace**;
- las alertas del **primary workspace** pueden correlacionarse con alertas de Microsoft Defender;
- los **secondary workspaces** mantienen su correlación de incidentes separada.

Este detalle puede ser relevante en preguntas sobre la experiencia unificada de Defender XDR y Sentinel.

1.1.2.10 Incident merging

La correlación no termina después de crear un incidente.

Microsoft Defender XDR sigue analizando las relaciones entre incidentes. Si determina posteriormente que dos incidentes representan realmente el mismo ataque, puede realizar un:

Incident merge

Las alertas y entidades relevantes pasan al incidente de destino, permitiendo al analista investigar una única historia de ataque.

Por tanto:

Alert correlation → agrupa alertas relacionadas.

Incident merging → combina incidentes que posteriormente se determina que pertenecen al mismo ataque.

1.1.2.11 Correlación manual

Aunque Defender realiza la correlación automáticamente, un analista también puede **mover una alerta de un incidente a otro** si determina que la clasificación automática no es correcta.

Una alerta debe pertenecer a un incidente, por lo que al moverla se modifica el incidente bajo el que será investigada.

1.1.2.12 Alert tuning vs. Allow indicator

Una distinción importante para el examen es:

Alert tuning → controla la generación, visualización o resolución de alertas.

Allow indicator → permite una entidad como un archivo, hash, certificado, IP o URL para evitar determinadas acciones de bloqueo.

Suprimir una alerta **no significa necesariamente permitir el objeto**.

Tras crear determinadas reglas de tuning, Defender puede ofrecer la posibilidad de añadir el IOC relacionado a una **allow list**, pero son mecanismos conceptualmente diferentes.

1.1.2.13 Escenarios típicos de examen

Escenario 1: una herramienta corporativa legítima genera repetidamente la misma alerta y el SOC quiere reducir el ruido.

Respuesta: Alert tuning rule

Escenario 2: se quiere que una actividad conocida no aparezca en la cola de alertas ni genere un incidente.

Respuesta: Hide alert

Escenario 3: se quiere mantener constancia de la alerta, pero cerrarla automáticamente.

Respuesta: Resolve alert

Escenario 4: se quiere conservar la señal para hunting, pero sin generar una alerta ni incidente.

Respuesta: Set as behavior

Escenario 5: Defender for Office 365, Defender for Identity y Defender for Endpoint detectan diferentes fases del mismo ataque.

Respuesta: Microsoft Defender XDR alert correlation

Escenario 6: el SOC quiere recibir un correo solamente cuando se produzcan alertas High severity en determinados endpoints.

Respuesta: Alert email notification rule filtrada por severity y device group

1.1.3 Configure Microsoft Defender for Endpoint advanced features

Las **Advanced features** de Microsoft Defender for Endpoint permiten habilitar capacidades adicionales de prevención, detección, investigación, respuesta e integración con otros productos de Microsoft.

Se configuran principalmente desde:

Microsoft Defender portal → Settings → Endpoints → Advanced features

La mayoría de estas opciones se activan o desactivan mediante un **toggle** y posteriormente se selecciona:

Save preferences

Para SC-200 no es necesario memorizar cada opción con el mismo nivel de detalle. Las más importantes son **EDR in block mode, tamper protection, Live Response, device discovery, indicators, automatic attack disruption, Intune integration y alert correlation**.

1.1.3.1 EDR in block mode

Endpoint Detection and Response (EDR) in block mode permite que Microsoft Defender for Endpoint **bloquee y remedie artefactos maliciosos detectados por EDR**, incluso cuando Microsoft Defender Antivirus no es el antivirus principal.

Su escenario más importante es:

Antivirus de terceros activo + Microsoft Defender Antivirus en passive mode

En esta situación, Defender Antivirus normalmente no actúa como antivirus principal, pero **EDR in block mode puede utilizarlo para bloquear o remediar amenazas detectadas por Defender for Endpoint**.

Se habilita desde:

Settings → Endpoints → Advanced features → Enable EDR in block mode

Cuando EDR detecta un artefacto malicioso:

EDR detection → Block/Remediate → acción registrada en Action Center

El estado puede aparecer como:

- **Blocked**
- **Prevented**

1.1.3.2 Tamper protection

Tamper protection evita que usuarios, malware o aplicaciones modifiquen determinadas configuraciones críticas de Microsoft Defender Antivirus.

Se habilita desde:

Settings → Endpoints → Advanced features → Tamper protection

1.1.3.3 Allow or block file

La opción:

Allow or block file

permite utilizar **custom indicators** para controlar la ejecución de archivos.

Para utilizar correctamente esta capacidad se requiere principalmente:

- Microsoft Defender Antivirus activo como solución antimalware;
- **cloud-delivered protection** habilitada.

Una vez habilitada, pueden crearse indicadores a partir del **hash de un archivo**.

La ruta para crear indicadores es:

Settings → Endpoints → Indicators

Entre las acciones disponibles para indicadores de archivos pueden encontrarse:

- **Allow**
- **Audit**
- **Warn**
- **Block execution**
- **Block and remediate**

Cuando se bloquea un archivo mediante un indicador, Defender puede impedir que sea:

read, written or executed

en los dispositivos afectados.

1.1.3.4 Custom network indicators

La opción:

> **Custom network indicators**

permite utilizar indicadores personalizados para:

- direcciones IP;
- dominios;
- URL.

Estos indicadores pueden utilizarse para **allow, audit, warn o block** conexiones relacionadas con dichos recursos.
Para habilitar esta capacidad:

> **Settings → Endpoints → Advanced features → Custom network indicators**

1.1.3.5 Automatically resolve alerts

La opción:

> **Automatically resolve alerts**

permite resolver automáticamente alertas cuando:

- no se encuentra finalmente ninguna amenaza;
- la amenaza detectada ha sido remediada correctamente.

Esto reduce el trabajo manual del SOC.
Sin embargo, si un analista establece manualmente una alerta como:

- **In progress**;
- **Resolved**;

el mecanismo automático no sobrescribe ese estado.
Además, el cierre automático puede afectar al cálculo del:

> **Device risk level**

porque éste depende, entre otros elementos, de las alertas activas asociadas al dispositivo.

1.1.3.6 Restrict correlation to within scoped device groups

Esta opción modifica cómo Defender XDR realiza la **correlación de alertas entre device groups**.

Por defecto, Defender puede correlacionar alertas pertenecientes a diferentes grupos de dispositivos dentro de un mismo incidente.

Si se habilita:

> **Restrict correlation to within scoped device groups**

la correlación queda limitada al ámbito de cada grupo.

Por ejemplo:

> Device Group A + Device Group B

Sin restricción:

> **Alertas A + B → un único incidente**

Con la restricción:

> **Alertas A → incidente A**
>
> **Alertas B → incidente B**

Esto puede ser útil cuando existen **SOC locales** con acceso únicamente a determinados grupos de dispositivos.

Microsoft recomienda no activarlo salvo que sea necesario, porque reduce la capacidad de **correlación global del ataque**.

Además:

> **el cambio solamente afecta a futuras correlaciones.**

1.1.3.7 Device discovery

Device discovery permite descubrir dispositivos presentes en la red corporativa que todavía **no están onboarded en Defender for Endpoint**.

Utiliza dispositivos ya onboarded como sensores para identificar otros activos.

El flujo conceptual es:

> **Onboarded devices → network discovery → unmanaged devices → Device inventory**

Existen dos modos principales:

- **Basic discovery**
- **Standard discovery**

Standard discovery es el modo recomendado y predeterminado. Además de observación pasiva, realiza determinadas comprobaciones activas para obtener información más completa de los dispositivos.

Basic discovery utiliza un enfoque más limitado y puede resultar apropiado en redes sensibles donde no se desea realizar active probing.

Actualmente la configuración detallada se realiza desde:

Settings → Device discovery

Authenticated network scans permiten descubrir y evaluar infraestructura de red que normalmente no puede ejecutar el sensor de Defender, como:

- switches;
- routers;
- firewalls;
- WLAN controllers;
- VPN gateways.

1.1.3.8 Live Response

Live Response proporciona al analista una **shell remota** sobre un dispositivo para realizar tareas de investigación y respuesta.

Debe habilitarse desde:

Settings → Endpoints → Advanced features → Live Response

Existe además una opción independiente para:

Live Response for servers

1.1.3.9 Unsigned scripts in Live Response

Por defecto debe mantenerse un enfoque restrictivo con los scripts utilizados en Live Response.

La opción:

Allow unsigned script execution

permite ejecutar **scripts no firmados** durante una sesión de Live Response.

Desde el punto de vista de seguridad:

habilitar unsigned scripts aumenta la flexibilidad, pero también aumenta el riesgo.

Por tanto, no debe confundirse:

- **Live Response** → habilita las sesiones remotas;
- **Live Response for servers** → permite sesiones sobre servidores;
- **Unsigned script execution** → permite ejecutar scripts no firmados dentro de Live Response.

1.1.3.10 Automatic attack disruption

Automatic attack disruption utiliza señales de Microsoft Defender XDR para detectar ataques en curso y ejecutar automáticamente acciones de contención.

Entre las acciones posibles se encuentran, dependiendo del producto y del activo:

- contener dispositivos no administrados;
- aislar determinados endpoints comprometidos;
- contener identidades comprometidas;
- otras acciones coordinadas entre productos de Defender.

El flujo puede verse como:

> **Signals → XDR correlation → High-confidence attack → Automatic containment**

Las acciones pueden revisarse posteriormente desde:

> **Incidents / Action Center**

No confundir con AIR:

> **AIR** investiga y remedia evidencias asociadas a una alerta o incidente.
>
> **Automatic attack disruption** intenta detener activamente un ataque en curso mediante acciones coordinadas de contención.

1.1.3.11 Microsoft Intune connection

Defender for Endpoint puede integrarse con **Microsoft Intune**.

La conexión permite compartir información sobre el **riesgo del dispositivo** con Intune y utilizarla posteriormente dentro de políticas de cumplimiento y **Microsoft Entra Conditional Access**.

Por ejemplo:

> Si Defender determina que un dispositivo tiene **High risk**, una política de Conditional Access puede impedir que acceda a determinados recursos corporativos.

1.1.3.12 Microsoft Defender for Cloud Apps integration

Esta integración envía señales de Defender for Endpoint a:

> **Microsoft Defender for Cloud Apps**

para proporcionar mayor visibilidad sobre el uso de aplicaciones cloud desde los endpoints.

Por tanto:

> **Endpoint telemetry → Defender for Cloud Apps → cloud app visibility**

Esto ayuda a identificar, por ejemplo, aplicaciones cloud utilizadas desde dispositivos corporativos.

1.1.3.13 Web content filtering

La opción **Web content filtering** permite bloquear el acceso a sitios web pertenecientes a determinadas categorías de contenido.

Debe distinguirse:

Web content filtering → bloqueo por categorías.

Custom network indicators → control de IP, URL o dominios concretos.

1.1.3.14 Unified audit log

Esta integración permite que determinadas actividades de Defender puedan formar parte del ecosistema de auditoría de Microsoft 365 y ser consultadas mediante:

Microsoft Purview Audit

Su finalidad es facilitar la investigación de actividades realizadas por usuarios y administradores.

1.1.3.15 Share endpoint alerts with Microsoft Purview

La opción de compartir alertas de endpoint permite enviar determinadas alertas y su estado de triaje hacia Microsoft Purview para utilizarlas, entre otros escenarios, en:

Insider Risk Management

Por tanto:

Defender for Endpoint alert → Microsoft Purview → Insider Risk

1.1.3.16 Hide potential duplicate device records

Defender puede detectar varias entradas que aparentemente corresponden al mismo dispositivo, por ejemplo debido a:

- device discovery;
- onboarding/offboarding;
- cambios en el dispositivo.

La opción:

Hide potential duplicate device records

oculta automáticamente registros duplicados y conserva visible el que Defender considera más preciso.

1.1.3.17 Download quarantined files

Permite almacenar de manera segura archivos puestos en cuarentena para que puedan ser posteriormente **descargados por un analista autorizado** para investigación.

Esta capacidad está habilitada por defecto.

Debe tratarse con precaución porque el archivo descargado puede ser realmente malicioso.

1.1.3.18 Authenticated telemetry

La opción:

Authenticated telemetry

permite autenticar la telemetría enviada hacia Defender for Endpoint con el objetivo de impedir que un atacante pueda:

spoof telemetry

y generar información falsa dentro del portal.

1.1.3.19 Streamlined connectivity

Defender for Endpoint dispone de un modelo simplificado de conectividad para el onboarding denominado:

Streamlined connectivity

que reduce el conjunto de endpoints de red necesarios para comunicarse con los servicios de Microsoft Defender.

Puede establecerse como opción predeterminada para nuevos dispositivos onboarded desde el portal.

Un dominio fundamental utilizado por el modelo simplificado es:

```
*.endpoint.security.microsoft.com
```

Los dispositivos ya onboarded no cambian automáticamente de modelo únicamente por modificar esta opción.

1.1.3.20 Preview features

Permite utilizar funcionalidades de Defender antes de alcanzar **General Availability (GA)**.

Debe recordarse que una funcionalidad en:

Preview

puede cambiar antes de su lanzamiento definitivo.

Actualmente, cuando las preview features generales de Defender XDR están habilitadas, pueden gestionarse desde las preferencias de Microsoft Defender XDR.

1.1.3.21 Endpoint Attack Notifications

Endpoint Attack Notifications proporciona investigación proactiva realizada por expertos de Microsoft sobre amenazas críticas detectadas en los datos de endpoint.

Las amenazas se priorizan en función de factores como:

- urgencia;
- impacto.

No debe confundirse con una simple regla de email:

> **Endpoint Attack Notifications → servicio de hunting/investigación sobre amenazas críticas.**
>
> **Email notification → envío automático de un correo cuando se cumple una condición.**

1.1.3.22 Resumen de las funcionalidades más importantes

Advanced feature	**Función principal**
EDR in block mode	Bloquear/remediar amenazas detectadas por EDR, especialmente con Defender Antivirus en passive mode.
Tamper protection	Impedir modificaciones no autorizadas de la configuración de seguridad.
Allow or block file	Aplicar indicadores sobre archivos.
Custom network indicators	Aplicar indicadores sobre IP, URL y dominios.
Automatically resolve alerts	Resolver automáticamente alertas ya remediadas o sin amenaza.
Scoped device group correlation	Limitar la correlación de alertas al ámbito de los device groups.
Device discovery	Descubrir dispositivos no onboarded o no administrados.
Live Response	Obtener una shell remota para investigación y respuesta.
Automatic attack disruption	Contener automáticamente ataques activos de alta confianza.
Microsoft Intune connection	Compartir device risk para compliance y Conditional Access.
Defender for Cloud Apps integration	Compartir señales de endpoint para analizar aplicaciones cloud.
Web content filtering	Bloquear sitios por categorías de contenido.
Authenticated telemetry	Impedir spoofing de telemetría.

1.1.4 Configure rules settings in Microsoft Defender for Endpoint

Microsoft Defender for Endpoint dispone de una sección específica denominada **Rules** desde la que se administran diferentes reglas relacionadas con indicadores, filtrado web, supresión de alertas y Automated Investigation and Response (AIR).

La ruta general es:

Microsoft Defender portal → Settings → Endpoints → Rules

1.1.4.1 Indicators

Los **Indicators of Compromise (IoCs)** permiten indicar explícitamente a Defender cómo debe tratar determinadas entidades conocidas.

Se administran desde:

Settings → Endpoints → Rules → Indicators

Al crear un indicador se especifican tres elementos fundamentales:

1. **Indicator**: entidad y, opcionalmente, fecha de expiración.
2. **Action**: acción que Defender realizará cuando detecte la entidad.
3. **Scope**: device groups sobre los que se aplicará.

Conceptualmente:

IoC + Action + Scope → Indicator rule

Las principales acciones disponibles son:

- **Allow**: permitir el indicador.
- **Audit**: permitirlo, pero generar una alerta cuando aparezca.
- **Warn**: advertir al usuario, permitiendo que continúe.
- **Block execution**: impedir la ejecución o acceso.
- **Block and remediate**: bloquear y ejecutar además una acción de remediación.

1.1.4.2 File indicators

Un **file indicator** normalmente identifica un archivo mediante su hash.

Para poder utilizar correctamente los indicadores de archivos deben estar habilitadas las capacidades correspondientes de Defender, especialmente:

Allow or block file

dentro de Advanced features.

1.1.4.3 IP, URL and domain indicators

Permiten controlar conexiones hacia:

- direcciones IP;
- dominios;
- URL concretas.

Por ejemplo:

`malicious.example.com`

puede configurarse como:

Block execution

para impedir que los dispositivos accedan al dominio.
En el caso de un dominio:

`example.com`

el indicador también puede afectar a sus subdominios:

`sub.example.com`

Los indicadores personalizados de red necesitan que esté habilitada la funcionalidad:

Custom network indicators

y utilizan capacidades como **Network Protection** y Microsoft Defender SmartScreen para aplicar las decisiones correspondientes.

1.1.4.4 Allow indicators

Un **Allow indicator** puede utilizarse para crear una excepción explícita sobre un recurso que la organización considera legítimo.

Allow indicator tiene precedencia sobre Web Content Filtering para ese recurso concreto.

1.1.4.5 Multiple Web Content Filtering policies

Si varias políticas afectan al mismo dispositivo, Defender aplica para cada categoría el resultado **más restrictivo**.
Por ejemplo:

Policy A → bloquea categorías 1 y 2

Policy B → bloquea categorías 3 y 4

El resultado será:

Categorías 1, 2, 3 y 4 bloqueadas.

Por tanto:

Block tiene precedencia sobre Audit.

Sin embargo, un **Allow indicator** específico puede utilizarse para permitir una URL o dominio concreto dentro de una categoría bloqueada.

1.1.4.6 Automation uploads

Automation uploads controla qué archivos pueden enviarse automáticamente a Microsoft durante una **Automated Investigation** para realizar análisis adicional en la nube.

Se configura desde:

Settings → Endpoints → Rules → Automation uploads

La opción principal es:

Content analysis

que puede habilitarse o deshabilitarse.

Cuando está habilitada, pueden especificarse extensiones de archivos y adjuntos que serán enviados automáticamente para inspección adicional.

Ejemplo:

```
exe, bat
```

Si durante una investigación automatizada aparecen archivos con esas extensiones, Defender puede:

Upload → Cloud analysis → Verdict

Microsoft almacena de forma segura los archivos enviados durante un máximo de aproximadamente **seis meses** antes de eliminarlos.

1.1.4.7 Automation folder exclusions

Las **Automation folder exclusions** permiten definir carpetas que **Automated Investigation and Remediation (AIR)** debe ignorar.

Se administran desde:

Settings → Endpoints → Rules → Automation folder exclusions

Una exclusión puede especificar:

- **Folder**: obligatorio.
- **Extensions**: opcional.
- **File names**: opcional.
- **Description**: obligatoria.

Por ejemplo:

```
C:\CorporateApp
```

puede configurarse para que AIR no investigue automáticamente determinados archivos legítimos utilizados por una aplicación corporativa.

Una exclusión de carpeta incluye sus:

subfolders

y puede limitarse adicionalmente utilizando nombres de archivos o extensiones.

1.1.4.8 Automation folder exclusions and AIR

La consecuencia más importante es:

> **Automation folder exclusion → AIR ignora los elementos excluidos.**

Es decir, durante una investigación automática Defender no analizará ni aplicará remediaciones sobre esos elementos.

Además, los comandos de **Live Response** destinados a recopilar o examinar esos archivos pueden devolver:

```
File is excluded
```

1.1.5 Configure custom data collection in Microsoft Defender for Endpoint

Custom Data Collection permite ampliar la telemetría que Microsoft Defender for Endpoint recopila por defecto, capturando eventos específicos de los endpoints y enviándolos a un **Microsoft Sentinel workspace** para su posterior análisis mediante hunting e investigación.

1.1.5.1 Cuándo utilizar Custom Data Collection

Debe utilizarse cuando la telemetría que Defender recopila por defecto no proporciona suficiente detalle para un escenario concreto.

Los principales casos de uso son:

- **Threat hunting**: recopilar eventos concretos necesarios para buscar técnicas de ataque.
- **Incident response**: obtener información forense adicional durante una investigación.
- **Application monitoring**: supervisar eventos relacionados con aplicaciones determinadas.
- **Compliance**: conservar determinados eventos como evidencia.
- **Lateral movement detection**: recopilar conexiones o ejecuciones relacionadas con movimiento lateral.

1.1.5.2 Flujo de funcionamiento

El funcionamiento puede resumirse como:

> **Custom Data Collection rule**
>
> ⇓
>
> **Dynamic tag / target devices**

⇓

Defender for Endpoint sensor

⇓

Eventos que cumplen las condiciones

⇓

Microsoft Sentinel workspace

⇓

KQL / Advanced Hunting / Investigation

El proceso tiene cinco pasos conceptuales:

1. Definir una regla de recopilación.
2. Seleccionar los dispositivos objetivo.
3. Defender distribuye la regla a esos endpoints.
4. Los endpoints recopilan únicamente los eventos coincidentes.
5. Los datos se envían a Microsoft Sentinel para su análisis.

1.1.5.3 Ruta de configuración

Las reglas se crean desde:

Microsoft Defender portal → Settings → Endpoints → Rules → Custom Data Collection

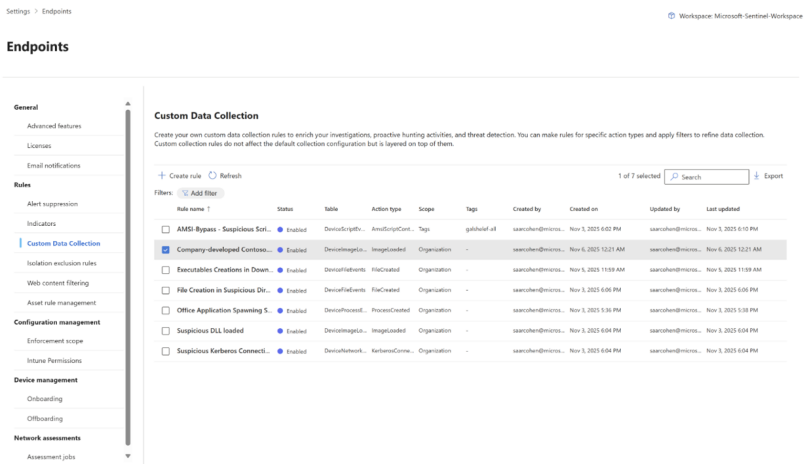


Figure 3: Caption

Desde esta página pueden:

- crearse reglas;
- editarse;
- habilitarse o deshabilitarse;
- eliminarse;
- comprobarse sus ámbitos.

1.1.5.4 Requisitos previos

Un detalle importante es que, aunque Sentinel ya esté conectado a Defender, durante la creación de la regla debe seleccionarse explícitamente el:

Microsoft Sentinel workspace

donde se almacenará la telemetría personalizada.

1.1.5.5 Dynamic tags

Custom Data Collection utiliza **dynamic tags** para determinar qué dispositivos reciben una regla.

Los dynamic tags se crean mediante:

Asset Rule Management

y permiten que los dispositivos entren o salgan automáticamente del ámbito en función de sus propiedades.

Ejemplo:

Dynamic tag = Domain Controllers

⇓

La regla Custom Data Collection se aplica automáticamente a los dispositivos que cumplan los criterios del tag.

Un punto especialmente importante para SC-200 es:

Manual/static tags NO están soportados.

Custom Data Collection requiere:

Dynamic tags

cuando se desea definir un ámbito específico de dispositivos.

1.1.5.6 Creación de una regla

Desde:

Settings → Endpoints → Rules → Custom Data Collection

se selecciona:

Create rule

La configuración principal incluye:

1. **General information**: nombre y descripción.
2. **Table**: tipo de evento que se quiere recopilar.
3. **Action**: acción o tipo concreto de evento.
4. **Conditions**: filtros adicionales.
5. **Scope**: dispositivos sobre los que se aplica.
6. **Review and finish**: revisión y creación.

1.1.5.7 Supported event tables

Custom Data Collection dispone de cinco tablas principales.

1.1.5.8 DeviceCustomProcessEvents

Se utiliza para recopilar eventos relacionados con **procesos**.

1.1.5.9 DeviceCustomImageLoadEvents

Recopila eventos relacionados con:

- DLL;
- imágenes;
- módulos cargados por procesos.

1.1.5.10 DeviceCustomFileEvents

Recopila actividad relacionada con archivos.

1.1.5.11 DeviceCustomNetworkEvents

Permite recopilar eventos de red que contienen información como:

- IP origen/destino;
- puertos;
- protocolos;
- conexiones.

1.1.5.12 DeviceCustomScriptEvents

Recopila eventos relacionados con la ejecución de scripts.

1.1.5.13 Conditions

Después de seleccionar una tabla y una acción pueden definirse condiciones para limitar qué eventos se recopilan.

Las condiciones dependen de la tabla seleccionada.

Ejemplos conceptuales:

```
ProcessCommandLine contains "powershell"

FileName endswith ".exe"

RemotePort == 445
```

Estas condiciones permiten aplicar:

filtering at collection time

de forma que Sentinel reciba únicamente la información necesaria.

1.1.5.14 Scope

La regla puede aplicarse a:

- todos los dispositivos compatibles;
- dispositivos concretos identificados mediante **dynamic tags**.

1.1.5.15 Deployment time

Una vez enviada la regla:

puede tardar aproximadamente entre 20 minutos y 1 hora

en desplegarse sobre los dispositivos objetivo.

Esto puede aparecer en preguntas de troubleshooting donde una regla recién creada todavía no produce eventos.

1.1.5.16 Límite de eventos

Cada regla puede recopilar como máximo:

> **75,000 eventos por dispositivo en una ventana móvil de 24 horas**

Si una regla alcanza este límite:

> **la recopilación de esa regla se detiene temporalmente para ese dispositivo**

hasta que se libere capacidad dentro de la ventana de 24 horas.
Importante:

> **otras reglas del mismo dispositivo continúan funcionando.**

Por tanto:

> Rule A alcanza 75,000 eventos → Rule A se detiene temporalmente.
>
> Rule B → continúa recopilando normalmente.

1.1.5.17 Consultar los datos

Una vez enviados, los eventos personalizados pueden consultarse mediante KQL utilizando las tablas correspondientes.

1.1.5.18 Monitorización y troubleshooting

Si una regla no genera datos deben comprobarse principalmente:

- que haya transcurrido suficiente tiempo para su deployment;
- que el dispositivo tenga el dynamic tag correcto;
- que el sistema operativo sea compatible;
- que las condiciones de la regla puedan cumplirse;
- que no se haya alcanzado el límite de 75,000 eventos;
- que determinadas EDR exclusions no interfieran con la recopilación.

Un problema típico:

> La regla se ha creado correctamente pero no aparecen eventos inmediatamente.
>
> **Posible causa: deployment todavía en curso; puede tardar hasta aproximadamente una hora.**

1.1.5.19 Enable, disable and delete

Una regla puede:

- editarse;
- habilitarse;
- deshabilitarse;
- eliminarse.

Al deshabilitarla:

> **la recopilación se detiene después del siguiente check-in del agente.**

1.1.5.20 Escenarios típicos de examen

Escenario 1: se necesita investigar posibles scripts maliciosos de PowerShell ejecutados en estaciones administrativas.

> **Custom Data Collection → DeviceCustomScriptEvents**

con scope basado en dynamic tags para las estaciones administrativas.
Escenario 2: se necesita recopilar conexiones hacia el puerto SMB en determinados servidores.

> **DeviceCustomNetworkEvents + condición RemotePort = 445**

Escenario 3: se quiere monitorizar cualquier modificación realizada en una carpeta con información crítica.

> **DeviceCustomFileEvents**

Escenario 4: se quieren detectar DLL sospechosas cargadas por determinados procesos.

> **DeviceCustomImageLoadEvents**

Escenario 5: se necesita conocer cada ejecución de una aplicación concreta.

> **DeviceCustomProcessEvents**

Escenario 6: se quiere aplicar una regla solamente a los Domain Controllers.

> **Dynamic tag + Custom Data Collection rule scope**

Escenario 7: una regla deja de enviar eventos pero otras reglas del mismo endpoint continúan funcionando.

Comprobar si la regla ha alcanzado el límite de **75,000 eventos por dispositivo / 24 horas**.

Escenario 8: se quiere generar una alerta cuando un determinado proceso aparezca.

Custom Detection, no solamente Custom Data Collection.

Custom Data Collection recopila el evento; Custom Detection es la que puede generar la alerta.

1.1.6 Configure security policies for Microsoft Defender for Endpoint, including attack surface reduction (ASR) rules

Microsoft Defender for Endpoint permite administrar **Endpoint security policies** directamente desde el portal de Microsoft Defender.

Estas políticas permiten configurar controles preventivos sobre los dispositivos protegidos sin necesidad de trabajar directamente desde el portal de Microsoft Intune.

La ruta principal es:

Microsoft Defender portal → Endpoints → Configuration management → Endpoint security policies

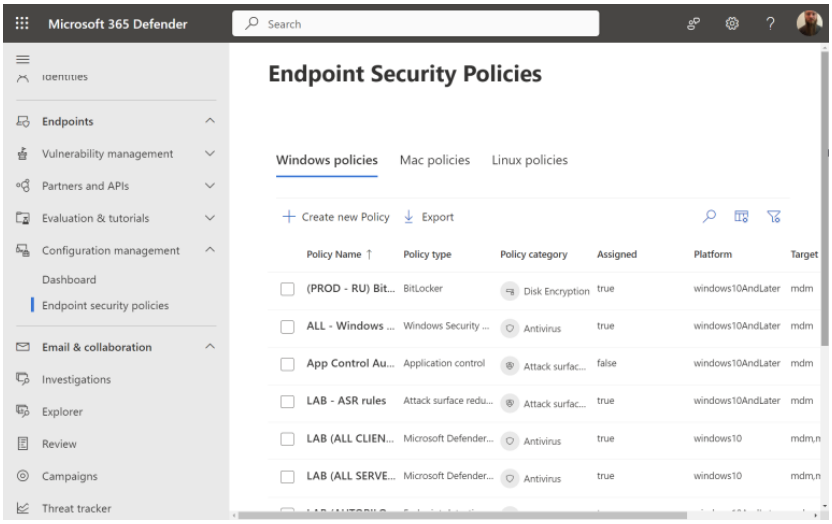


Figure 4: Caption

1.1.6.1 Tipos de Endpoint security policies

Desde el portal de Defender pueden administrarse actualmente los siguientes tipos principales de políticas:

Policy	Plataforma	Función
Attack surface reduction rules	Windows	Bloquear comportamientos utilizados habitualmente por atacantes.
Defender update controls	Windows	Controlar actualizaciones de Defender.
Device control	Windows	Controlar dispositivos periféricos.
Endpoint Detection and Response	Windows, macOS, Linux	Configurar capacidades EDR.
Microsoft Defender Antivirus	Windows, macOS, Linux	Configurar protección antimalware.
Microsoft Defender Antivirus exclusions	Windows, macOS, Linux	Configurar exclusiones del antivirus.
Microsoft Defender Firewall	Windows	Configurar el firewall.
Microsoft Defender Firewall rules	Windows	Crear reglas específicas del firewall.
Microsoft Defender global exclusions	Linux	Exclusiones globales de AV/EDR.
Windows Security experience	Windows	Configurar la experiencia de Windows Security.

Un detalle importante es que las políticas de **Device Control** creadas desde Defender solamente se aplican a dispositivos **enrolled in Intune**; no se aplican a dispositivos administrados únicamente mediante Defender for Endpoint Security Settings Management.

1.1.6.2 Security Settings Management

Una capacidad que permite aplicar determinadas políticas de seguridad a dispositivos:

> **onboarded en Defender for Endpoint pero no enrolled en Intune**

De esta forma, un dispositivo no necesita estar completamente administrado mediante Intune para recibir determinadas configuraciones de seguridad.

Se habilita desde:

Settings → Endpoints → Configuration management → Enforcement scope

Puede configurarse para diferentes plataformas y aplicarse inicialmente únicamente a dispositivos etiquetados para realizar un despliegue progresivo.

Por ejemplo:

On tagged devices

utilizando el tag:

`MDE-Management`

1.1.6.3 Intune enrolled vs. MDE managed

Es importante distinguir:

Intune enrolled device

El dispositivo está administrado directamente mediante Intune.

MDE Security Settings Management device

El dispositivo está onboarded en Defender for Endpoint y Defender puede aplicar determinadas políticas de seguridad aunque el equipo no esté enrolled en Intune.

Para dispositivos administrados únicamente mediante Defender for Endpoint Security Settings Management:

las políticas deben asignarse a Microsoft Entra device groups.

No se admite targeting mediante grupos de usuarios.

En dispositivos administrados mediante Intune sí pueden utilizarse:

- grupos de dispositivos;
- grupos de usuarios.

1.1.6.4 Creación de una Endpoint security policy

La creación sigue generalmente este flujo:

1. Abrir **Endpoint security policies**.
2. Seleccionar **Create new policy**.
3. Seleccionar la **platform**.
4. Seleccionar el **template**.
5. Configurar los **security settings**.

6. Definir las **assignments**.
7. Revisar y seleccionar **Save**.

Por ejemplo, para configurar ASR:

Platform = Windows

Template = Attack surface reduction rules

1.1.6.5 Assignments

Una política puede aplicarse a grupos de Microsoft Entra utilizando:

- **Include**: incluir el grupo.
- **Exclude**: excluir el grupo.

Esto permite realizar despliegues progresivos.

1.1.6.6 Policy deployment

Una Endpoint security policy puede tardar aproximadamente:

hasta 90 minutos

en llegar al dispositivo.
Desde la página del dispositivo puede forzarse una sincronización mediante:

Device → More actions → Policy sync

Con Policy sync, Microsoft indica que normalmente la política debería aplicarse aproximadamente en:

10 minutos

1.1.6.7 Attack Surface Reduction

Las capacidades de **Attack Surface Reduction** tienen como objetivo reducir las técnicas y superficies que un atacante puede utilizar para comprometer un endpoint.
Dentro de este conjunto se incluyen tecnologías como:

- Attack Surface Reduction rules;
- Network Protection;
- Controlled Folder Access;
- Web Protection;
- Device Control;
- Exploit Protection.

En este objetivo del examen, las más importantes son las:

Attack Surface Reduction Rules (ASR rules)

1.1.6.8 Qué son las ASR rules

Las **ASR rules** son reglas preventivas de Microsoft Defender Antivirus diseñadas para bloquear comportamientos legítimos técnicamente posibles pero que son utilizados frecuentemente por malware y atacantes.

Por ejemplo:

- Word ejecutando PowerShell;
- una macro de Office creando un ejecutable;
- scripts ofuscados....

Por tanto, busca principalmente:

> **comportamientos de software potencialmente peligrosos.**

Ésta es una diferencia importante respecto a un antivirus tradicional basado únicamente en malware conocido.

1.1.6.9 Requisitos de ASR

Las ASR rules son una funcionalidad de:

> **Microsoft Defender Antivirus**

y requieren que Defender Antivirus esté:

- habilitado;
- en **Active mode**;
- con **Real-time protection** habilitada.

No funcionan correctamente como mecanismo ASR cuando Defender Antivirus está en:

- Passive mode;
- Passive mode + EDR in block mode;
- Limited Periodic Scanning;
- Off.

Trampa importante:

> **EDR in block mode puede funcionar con Defender Antivirus en Passive mode, pero ASR rules requieren Defender Antivirus Active.**

1.1.6.10 Sistemas operativos

Las ASR rules son una capacidad específica de:

Windows

No están disponibles para:

- macOS;
- Linux.

aunque dichos dispositivos estén onboarded en Defender for Endpoint.

1.1.6.11 Modos de las ASR rules

Cada regla puede configurarse en varios modos.

Modo	Código	Comportamiento
Disabled / Off	0	La regla está deshabilitada explícitamente.
Block	1	El comportamiento se bloquea.
Audit	2	Se registra qué habría bloqueado la regla, pero no se impide la acción.
Not configured	5	La regla no se configura explícitamente.
Warn	6	Se bloquea inicialmente, pero el usuario puede realizar un bypass temporal.

1.1.6.12 Audit mode

Audit es fundamental al desplegar nuevas ASR rules.
La regla:

detecta el comportamiento pero no lo bloquea.

La estrategia recomendada para muchas reglas es:

Audit → Analyze → Configure exclusions → Block/Warn

Microsoft recomienda probar normalmente las reglas en Audit antes de pasarlas a Block o Warn, salvo determinadas **standard protection rules** que pueden desplegarse directamente con mayor confianza.

1.1.6.13 Block mode

En:

Block

Defender impide la operación que coincide con la regla.

1.1.6.14 Warn mode

Warn funciona inicialmente como Block, pero muestra una advertencia al usuario.
El usuario puede seleccionar:

Unblock

para permitir temporalmente esa actividad.
El bypass dura:

24 horas

Después debe volver a autorizarse si la acción vuelve a ejecutarse.
Por tanto:

Block → no permite bypass.

Warn → permite bypass temporal por el usuario.

No todas las ASR rules soportan Warn.

1.1.6.15 Standard protection rules

Microsoft identifica tres reglas como:

Standard protection rules

que conviene memorizar para SC-200:

1. **Block abuse of exploited vulnerable signed drivers**
2. **Block credential stealing from the Windows local security authority subsystem**
3. **Block persistence through WMI event subscription**

Estas reglas protegen frente a técnicas muy frecuentes y Microsoft indica que normalmente pueden habilitarse en **Block o Warn** sin realizar previamente el mismo nivel de pruebas requerido para otras reglas.

1.1.6.16 Block abuse of exploited vulnerable signed drivers

Evita que aplicaciones escriban en el sistema drivers firmados conocidos como vulnerables.

1.1.6.17 Block credential stealing from LSASS

Protege:

LSASS – Local Security Authority Subsystem Service

frente a técnicas de extracción de credenciales.
Ejemplo típico:

Malware intenta leer memoria de LSASS para obtener credenciales.

⇓

ASR blocks credential stealing

1.1.6.18 Block persistence through WMI event subscription

Impide que un atacante utilice:

WMI event subscriptions

como mecanismo de persistencia.

WMI puede utilizarse legítimamente para administración, pero también puede permitir que un atacante ejecute código automáticamente cuando ocurre determinado evento.

1.1.6.19 Otras ASR rules importantes

No es necesario memorizar todos sus GUID, pero sí reconocer el escenario asociado a las reglas principales.

- **Block all Office applications from creating child processes**

  “‘ Impide que Word, Excel, PowerPoint, OneNote o Access lancen procesos hijos como `cmd.exe` o PowerShell.

- **Block Office applications from creating executable content**

  Impide que aplicaciones de Office creen contenido ejecutable en disco.

- **Block Office applications from injecting code into other processes**

  Evita técnicas de *process injection* iniciadas desde Office.

- **Block executable content from email client and webmail**

  Bloquea contenido ejecutable procedente del correo electrónico.

- **Block execution of potentially obfuscated scripts**

  Evita scripts deliberadamente ofuscados utilizados para ocultar actividad maliciosa.

- **Block JavaScript or VBScript from launching downloaded executable content**

  Impide que JavaScript o VBScript ejecuten contenido descargado.

- **Block executable files from running unless they meet a prevalence, age, or trusted list criterion**

  Utiliza reputación, antigüedad y prevalencia en la nube de Microsoft para impedir ejecutables poco conocidos o no confiables.

- **Block process creations originating from PSExec and WMI commands**

  Evita creación de procesos mediante PsExec o WMI, técnicas habituales de ejecución remota y movimiento lateral.

- **Block untrusted and unsigned processes that run from USB**

  Impide ejecutar procesos no confiables o no firmados desde dispositivos USB.

- **Block Win32 API calls from Office macros**

  Evita que macros de Office utilicen llamadas Win32 API potencialmente peligrosas.

- **Use advanced protection against ransomware**

  Añade protección específica contra ransomware utilizando heurística local y en la nube.

- **Block rebooting machine in Safe Mode**

  Evita que un atacante reinicie Windows en Safe Mode mediante técnicas comúnmente abusadas para desactivar o limitar herramientas de seguridad.

- **Block Webshell creation for Servers**

  Protege servidores frente a la creación de web shells. “‘

1.1.6.20 Cloud-delivered protection

Algunas reglas utilizan información procedente del servicio cloud de Microsoft.
Dos ejemplos especialmente importantes son:

- **Block executable files from running unless they meet a prevalence, age, or trusted list criterion**.
- **Use advanced protection against ransomware**.

Estas reglas dependen de:

Microsoft Defender Antivirus + Cloud-delivered protection

Por ello, si una pregunta plantea que una regla basada en reputación cloud no funciona correctamente, debe comprobarse:

Cloud-delivered protection

1.1.6.21 ASR exclusions

Una aplicación legítima puede comportarse de una forma que una ASR rule considere peligrosa.
Para estos casos pueden configurarse:

1. **Global ASR exclusions**
2. **Per-rule ASR exclusions**

Global ASR exclusions Una exclusión global:

se aplica a todas las ASR rules.

Ejemplo:

`C:\CorporateApp\app.exe`

Si se añade como exclusión global, las reglas ASR dejan de evaluar ese archivo.

Debe utilizarse con precaución porque reduce la protección de:

todas las ASR rules

sobre ese elemento.

Per-rule exclusions Una exclusión:

Per-ASR rule

afecta únicamente a una regla determinada.

1.1.6.22 Exclusiones y seguridad

Microsoft advierte que una exclusión ASR reduce significativamente la protección.

Cuando un elemento está excluido:

la ASR rule no lo bloquea y puede dejar de generar los eventos asociados.

Por ello, antes de crear exclusiones se recomienda:

Audit mode

para determinar exactamente qué aplicación o comportamiento requiere una excepción.

1.1.6.23 Controlled Folder Access

Aunque no es una ASR rule individual, **Controlled Folder Access (CFA)** forma parte de las capacidades de Attack Surface Reduction.

Puede configurarse dentro de las políticas de Attack Surface Reduction mediante opciones como:

- Enable Controlled Folder Access;
- Controlled folder access protected folders;
- Controlled folder access allowed applications.

1.1.6.24 Despliegue recomendado de ASR

Microsoft recomienda un despliegue progresivo:

1. Seleccionar las reglas.
2. Activarlas inicialmente en **Audit**.
3. Analizar resultados.
4. Identificar falsos positivos.
5. Configurar exclusiones mínimas necesarias.
6. Cambiar a **Warn o Block**.
7. Ampliar progresivamente el deployment ring.

1.1.6.25 Escenarios típicos de examen

Escenario 1: dispositivos onboarded en Defender for Endpoint no están enrolled en Intune, pero necesitan recibir políticas de seguridad.

Defender for Endpoint Security Settings Management

y habilitar:

Configuration management → Enforcement scope

Escenario 2: antes de bloquear una conducta con una nueva ASR rule se quiere conocer el impacto sobre aplicaciones corporativas.

Audit mode

Escenario 3: se quiere bloquear una conducta pero permitir al usuario realizar temporalmente una excepción.

Warn mode

El bypass dura aproximadamente:

24 horas

Escenario 4: Word está ejecutando PowerShell después de abrir un documento malicioso.

Block all Office applications from creating child processes

Escenario 5: malware intenta extraer credenciales almacenadas en LSASS.

Block credential stealing from the Windows local security authority subsystem

Escenario 6: se detecta ejecución remota y movimiento lateral mediante PsExec.

> **Block process creations originating from PSExec and WMI commands**

Escenario 7: una aplicación corporativa legítima entra en conflicto únicamente con una ASR rule.

> **Per-ASR rule exclusion**

preferible a una exclusión global.
Escenario 8: se quiere proteger Documentos y otras carpetas frente a modificaciones realizadas por aplicaciones no confiables.

> **Controlled Folder Access**

Escenario 9: se quiere añadir una capa adicional de protección basada en heurística local y cloud frente a ransomware.

> **Use advanced protection against ransomware**

Escenario 10: Defender Antivirus está en Passive mode debido a un antivirus de terceros y se quiere utilizar ASR.

> **No es un escenario válido: ASR requiere Defender Antivirus en Active mode.**

EDR in block mode sí está diseñado específicamente para proporcionar protección adicional en escenarios con Defender Antivirus en Passive mode.

1.1.7 Manage automated investigation and response capabilities in Microsoft Defender XDR

Automated Investigation and Response (AIR) permite a Microsoft Defender XDR investigar automáticamente alertas, analizar las entidades relacionadas, determinar un veredicto y ejecutar o recomendar acciones de remediación.
Microsoft lo describe conceptualmente como un:

> **virtual security analyst**

capaz de reproducir automáticamente muchas de las tareas que realizaría un analista SOC de nivel 1 o 2.
El flujo fundamental que debe memorizarse es:

> **Alert → Incident → Automated investigation → Evidence analysis → Verdict → Remediation**

AIR puede trabajar con señales procedentes de diferentes componentes de Microsoft Defender XDR:

- **Defender for Endpoint**: dispositivos, procesos, archivos y otras evidencias de endpoint.
- **Defender for Office 365**: correos, adjuntos, URL y buzones.
- **Defender for Identity**: identidades, usuarios y actividad de Active Directory.

Esto permite investigar un ataque de forma transversal en lugar de analizar cada alerta de forma aislada.

1.1.7.1 Funcionamiento de AIR

Cuando una alerta genera un incidente, Defender puede iniciar automáticamente una investigación.

Durante la investigación:

1. analiza las evidencias asociadas;
2. busca otras entidades relacionadas;
3. amplía el alcance de la investigación cuando encuentra relaciones;
4. asigna un veredicto a cada evidencia;
5. determina las acciones de remediación necesarias;
6. ejecuta automáticamente las acciones o solicita aprobación, dependiendo de la configuración.

Mientras una investigación está activa, nuevas alertas relacionadas pueden añadirse a la misma investigación.

Además, si una entidad maliciosa aparece en otro dispositivo, Defender puede ampliar el alcance:

> **Threat on Device A → same entity on Device B → investigation expands to Device B**

1.1.7.2 Verdicts

AIR genera un veredicto para las evidencias investigadas.

Los tres resultados principales son:

Verdict	**Significado**
Malicious	La evidencia ha sido determinada como maliciosa y puede requerir remediación.
Suspicious	Existe actividad sospechosa, pero no suficiente certeza para considerarla definitivamente maliciosa.
No threats found	No se ha identificado una amenaza y no se requiere remediación.

1.1.7.3 Remediation actions

Cuando AIR determina que una entidad es maliciosa o sospechosa puede generar acciones de remediación.

En endpoints, entre las acciones más importantes se encuentran:

- poner un archivo en cuarentena;
- detener un proceso;
- eliminar una clave de registro;
- detener un servicio;
- deshabilitar un driver;
- eliminar una scheduled task;
- aislar un dispositivo;
- restringir la ejecución de código;
- ejecutar un análisis antivirus.

En correo electrónico pueden existir acciones como:

- **Soft delete** de mensajes o clusters;
- poner mensajes en cuarentena;
- bloquear una URL;
- eliminar o poner en cuarentena adjuntos;
- desactivar external mail forwarding.

Sobre identidades pueden aparecer acciones como:

- deshabilitar un usuario;
- resetear su contraseña;
- confirmar al usuario como comprometido.

No todas las acciones son necesariamente ejecutadas automáticamente.
Esto depende de:

Verdict + Automation level + Security configuration

1.1.7.4 Automation levels en Defender for Endpoint

Define el grado de autonomía de AIR en Microsoft Defender for Endpoint.

Estos niveles se configuran por:

Device group

desde:

Settings → Endpoints → Permissions → Device groups

Al crear o editar un device group se selecciona su:

Remediation level / Automation level

Los niveles principales son:

Automation level	**Comportamiento**
Full – remediate threats automatically	Defender ejecuta automáticamente las acciones de remediación para evidencias consideradas maliciosas. Es el nivel recomendado.
Semi – require approval for all folders	Las acciones de remediación sobre archivos requieren aprobación del SOC.
Semi – require approval for core folders remediation	Las acciones sobre archivos en directorios críticos del sistema requieren aprobación; fuera de ellos pueden ejecutarse automáticamente.
Semi – require approval for non-temp folders remediation	Los archivos en carpetas temporales pueden remediarse automáticamente; en otras carpetas se necesita aprobación.
No automated response	No se ejecutan investigaciones automatizadas ni remediaciones AIR en esos dispositivos. No recomendado.

Las acciones de remediación correspondientes se ejecutan automáticamente. Posteriormente pueden revisarse desde:

Action center → History

y determinadas acciones pueden deshacerse.

Éste es el modo recomendado por Microsoft para reducir el tiempo entre:

Detection → Investigation → Remediation

1.1.7.5 Semi automation

Los modos **Semi** permiten mantener intervención humana sobre determinadas acciones.

Por ejemplo:

Semi – require approval for all folders

provoca que las acciones propuestas aparezcan como:

Pending approval

El analista debe:

Approve

o:

Reject

la acción.

Las acciones pendientes pueden expirar después de:

7 días

y, si expiran, se comportan como si hubiesen sido rechazadas.

1.1.7.6 Suspicious evidence

Pueden requerir aprobación del analista antes de aplicar una remediación.

Esto evita que Defender ejecute automáticamente determinadas acciones destructivas cuando no existe suficiente confianza para clasificar la evidencia como definitivamente maliciosa.

1.1.7.7 No threats found

No se genera ninguna acción de remediación.

1.1.7.8 Action Center

Todas las acciones relevantes de respuesta de Microsoft Defender XDR se centralizan en:

Actions & submissions → Action center

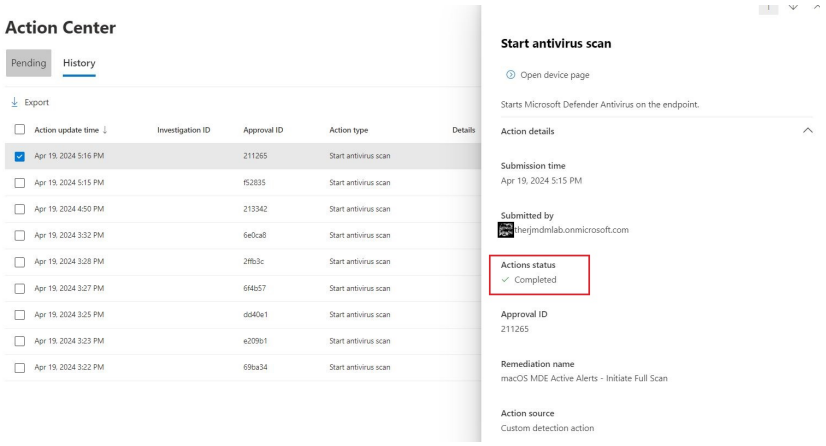


Figure 5: Caption

Las dos pestañas fundamentales son:

Pestaña	**Función**
Pending	Acciones propuestas que requieren aprobación o rechazo.
History	Acciones que ya se han ejecutado; actúa como registro histórico y permite deshacer determinadas acciones.

Ésta es una distinción muy importante:

Pending → Approve / Reject

History → Review / Undo

1.1.7.9 Approve and Reject

Cuando una remediación requiere intervención humana:

Action Center → Pending

el analista puede seleccionar:

- **Approve**: ejecuta la acción propuesta.
- **Reject**: impide que se ejecute.

También es posible revisar determinadas acciones pendientes desde:

Incidents → Evidence and Response

cuando el incidente muestra:

Remediation status = Pending approval

1.1.7.10 Undo remediation actions

Una acción ya ejecutada no significa necesariamente que sea irreversible.
Desde:

Action Center → History

pueden deshacerse determinadas acciones.
Entre ellas:

- aislar un dispositivo;
- poner un archivo en cuarentena;
- eliminar una clave del registro;
- eliminar una scheduled task;
- detener un servicio;
- deshabilitar un driver;
- restringir la ejecución de código.

1.1.7.11 Action source

Esta columna permite identificar el origen de cada acción.
Entre los posibles orígenes se encuentran:

- Manual device action;
- Manual email action;
- Automated device action;
- Automated email action;
- Advanced hunting action;
- Explorer action;
- Manual Live Response action;
- acciones realizadas mediante APIs.

Por tanto:

Action Center ≠ solamente AIR

Es el repositorio centralizado de acciones de respuesta de Defender XDR.

1.1.7.12 Permisos

Para aprobar o rechazar acciones de remediación sobre dispositivos, un usuario puede necesitar, según el modelo de permisos:

Security Administrator

o, con Microsoft Defender XDR Unified RBAC:

Security operations → Security data → Response (manage)

Para remediar contenido de Defender for Office 365 se necesitan además los permisos correspondientes de Email & collaboration, entre ellos las capacidades relacionadas con:

Search and Purge

1.1.7.13 Escenarios típicos de examen

Escenario 1: se quiere que las amenazas maliciosas detectadas en endpoints sean remediadas automáticamente sin aprobación del SOC.

Device group → Full – remediate threats automatically

Escenario 2: todas las remediaciones de archivos deben ser revisadas por un analista.

Semi – require approval for all folders

Escenario 3: solamente se quiere exigir aprobación cuando el archivo se encuentre en directorios críticos de Windows.

Semi – require approval for core folders remediation

Escenario 4: se quiere que los archivos maliciosos de carpetas temporales se eliminen automáticamente, pero que el resto requieran aprobación.

Semi – require approval for non-temp folders remediation

Escenario 5: el SOC debe revisar acciones recomendadas por AIR antes de ejecutarlas.

Action Center → Pending

Escenario 6: una remediación automática ha resultado ser un falso positivo y debe revertirse.

Action Center → History → Undo

si la acción admite reversión.

Escenario 7: se necesita comprobar todas las acciones ejecutadas automáticamente por Defender.

Action Center → History

Escenario 8: se quiere iniciar manualmente una investigación AIR sobre un endpoint con la experiencia actual posterior al 1 de septiembre de 2026.

No se inicia manualmente AIR en Defender for Endpoint; para investigación bajo demanda se utiliza un Full antivirus scan.

Escenario 9: Defender detecta ransomware activo y necesita contener inmediatamente dispositivos o identidades para evitar movimiento lateral.

Automatic Attack Disruption

no simplemente AIR.

Escenario 10: un usuario informa de un correo de phishing y se quiere investigar automáticamente el mensaje y otros mensajes relacionados.

Defender for Office 365 AIR

1.1.8 Configure automatic attack disruption in Microsoft Defender XDR

Automatic Attack Disruption está integrado en Microsoft Defender XDR y actúa automáticamente cuando Defender identifica con **alta confianza** un ataque activo.

Para SC-200, lo importante es saber:

- qué productos deben estar correctamente desplegados;
- qué acciones automáticas puede ejecutar;
- cómo afectan los automation levels;
- cómo configurar exclusiones;
- cómo identificar y revisar una disrupción.

1.1.8.1 Acciones automáticas principales

Las acciones más importantes que debe reconocerse en el examen son:

Acción	Resultado
Contain device	Impide que un dispositivo no administrado se comunique con dispositivos administrados.
Isolate device	Aísla automáticamente un endpoint comprometido de la red. Actualmente esta automatización está en Preview.
Contain user	Restringe la actividad de una identidad comprometida sobre los endpoints protegidos.
Disable user	Deshabilita una cuenta comprometida de Active Directory.
Revoke user session	Revoca sesiones activas del usuario.
Suspend user in Entra	Suspende la cuenta en Microsoft Entra ID.
OAuth app response	Aplica medidas de protección sobre una aplicación OAuth comprometida.

1.1.8.2 Contain device

Contain device está pensado principalmente para dispositivos:

discovered but not onboarded

Cuando Defender identifica un dispositivo no administrado como parte de un ataque, puede ordenar a los dispositivos administrados que bloqueen la comunicación con él.

Para que esta funcionalidad pueda utilizarse es necesario que:

Device discovery = Standard discovery

en Microsoft Defender for Endpoint.

1.1.8.3 Automatic device isolation

Automatic Attack Disruption también puede:

aislar automáticamente un endpoint comprometido

cuando éste constituye un punto activo dentro del ataque.
El aislamiento:

- bloquea la mayor parte del tráfico de red;
- mantiene la conectividad necesaria con los servicios de seguridad de Defender;
- afecta únicamente a los dispositivos involucrados en el incidente;
- puede revertirse automáticamente después de un periodo determinado;
- puede revertirse antes manualmente por el SOC.

1.1.8.4 Contain user

Contain user actúa principalmente en la:

endpoint layer

Defender for Endpoint aplica una política sobre los endpoints onboarded que restringe la actividad de la identidad comprometida.
Puede limitar:

- acceso basado en autenticación;
- acceso al sistema de archivos;
- conexiones de red;
- SMB;
- RPC;
- determinadas sesiones remotas.

Su objetivo es reducir especialmente:

lateral movement

1.1.8.5 Disable user

Cuando una identidad del DA está comprometida, Defender for Identity puede ejecutar:

Disable user

a través de los Domain Controllers donde está desplegado su sensor.

1.1.8.6 Estado de Microsoft Defender Antivirus

Automatic Attack Disruption puede actuar sobre endpoints independientemente de que Microsoft Defender Antivirus esté en:

- **Active**;
- **Passive**;
- **EDR in block mode**.

Esto es una diferencia importante respecto a las ASR rules.

ASR → Defender Antivirus Active

Attack Disruption → puede actuar con AV Active, Passive o EDR Block Mode

1.1.8.7 Requisitos de Defender for Identity

Para que Defender for Identity pueda participar correctamente en Automatic Attack Disruption deben estar configurados:

- los eventos de auditoría necesarios en los Domain Controllers;
- los sensores de Defender for Identity;
- las capacidades necesarias para realizar acciones sobre cuentas.

Esto permite acciones como:

Disable user

sobre cuentas comprometidas de Active Directory.

1.1.8.8 Requisitos de Defender for Cloud Apps

Defender for Cloud Apps debe estar correctamente conectado a Microsoft 365 mediante su:

Microsoft 365 connector

Microsoft indica que deben habilitarse todas las opciones requeridas del conector, incluida la integración correspondiente con:

Microsoft Entra ID apps

Una configuración incompleta puede impedir determinadas acciones automáticas.

1.1.8.9 Requisitos de Defender for Office 365

Para los escenarios relacionados con correo:

los buzones deben estar hospedados en Exchange Online

y debe existir auditoría de determinados eventos de mailbox.
Entre los eventos relevantes se encuentran:

- `MailItemsAccessed`;
- `UpdateInboxRules`;
- `MoveToDeletedItems`;
- `SoftDelete`;
- `HardDelete`.

1.1.8.10 Exclusiones de Automatic Attack Disruption

Puede ser necesario proteger determinados activos críticos frente a acciones automáticas.

Microsoft permite excluir principalmente:

- **user accounts**;
- **device groups**;
- **IP addresses / ranges**.

Debe utilizarse con precaución:

> **una exclusión reduce la capacidad de Defender para contener automáticamente un ataque.**

1.1.8.11 User exclusions

Se configuran desde:

> **Settings → Microsoft Defender XDR → Automated response → Identities**

y permiten excluir cuentas como:

- service accounts;
- emergency administrator accounts;
- cuentas asociadas a servicios críticos.

Una cuenta excluida no será automáticamente deshabilitada por Attack Disruption.

1.1.8.12 Device group exclusions

Se configuran desde:

> **Settings → Microsoft Defender XDR → Automated response → Devices**

Para excluir completamente un device group de respuestas automatizadas puede configurarse:

> **No automated response**

Debe recordarse que esta configuración afecta también a otras capacidades automáticas asociadas a los dispositivos, por lo que debe utilizarse con precaución.

1.1.8.13 Policy application exclusions

Microsoft dispone además, actualmente en **Preview**, de controles más granulares de:

Policy application

que permiten mantener Attack Disruption habilitado pero desactivar determinadas acciones para grupos concretos.

El mecanismo utiliza:

Dynamic tags

1.1.8.14 Cómo identificar que se ha producido Attack Disruption

En la cola de incidentes aparecerá:

Attack Disruption

como tag del incidente.

Al abrir el incidente pueden aparecer:

- tag **Attack Disruption**;
- tipo de amenaza detectada, por ejemplo ransomware;
- banner indicando que el ataque ha sido interrumpido;
- estado de los activos contenidos dentro del incident graph;
- tarjeta resumen de las acciones de disruption.

1.1.8.15 Reversión de las acciones

Una vez investigado y mitigado el ataque, el analista puede revertir determinadas acciones.

Por ejemplo:

Contained device → Release from containment

Disabled user → Enable user

No debe liberarse un activo mientras siga existiendo riesgo de compromiso, porque el atacante podría recuperar acceso.

1.1.8.16 Advanced Hunting

Las acciones y efectos de Attack Disruption pueden investigarse mediante:

```
DisruptionAndResponseEvents
```

Esta tabla proporciona una visión centralizada de los eventos relacionados con mecanismos automáticos de respuesta.

1.1.8.17 Escenarios típicos de examen

Escenario 1: Defender detecta que un equipo no onboarded está participando en movimiento lateral y quiere impedir que se comunique con equipos protegidos.

> **Contain device**

y Device Discovery debe estar configurado como:

> **Standard discovery**

Escenario 2: una cuenta comprometida está intentando acceder mediante SMB y RPC a múltiples endpoints.

> **Contain user**

Escenario 3: una cuenta de Active Directory ha sido comprometida y se quiere impedir completamente su utilización.

> **Disable user mediante Defender for Identity**

Escenario 4: un servidor crítico nunca debe quedar sometido a determinadas acciones automáticas de disruption.

> **Attack Disruption exclusion / Policy application exclusion**

Escenario 5: un incidente muestra un tag **Attack Disruption**.

> Defender XDR ha ejecutado automáticamente una o varias acciones de contención sobre el ataque.

Escenario 6: el device group tiene Automation level = Semi y se pregunta si Attack Disruption puede contener automáticamente un activo.

> **Sí. Semi automation no exige aprobación para Automatic Attack Disruption.**

Escenario 7: se quiere evitar completamente la actuación automática de Attack Disruption sobre un determinado device group.

> **No automated response**

aunque Microsoft recomienda limitar su uso.
Escenario 8: se necesitan consultar mediante KQL las acciones relacionadas con Attack Disruption en toda la organización.

> `DisruptionAndResponseEvents`

1.1.9 Configure and manage device groups, permissions, and automation levels in Microsoft Defender for Endpoint

Los **device groups** permiten segmentar los endpoints de Microsoft Defender for Endpoint para aplicar:

- diferentes niveles de remediación automática;
- diferentes ámbitos de acceso mediante RBAC;
- filtrado de dispositivos durante investigaciones;
- determinadas configuraciones y reglas basadas en grupos.

La ruta principal es:

Settings → Endpoints → Permissions → Device groups

También pueden administrarse desde la experiencia de permisos mediante:

Permissions → Endpoints roles & groups

La creación de device groups está disponible tanto en:

- Microsoft Defender for Endpoint Plan 1;
- Microsoft Defender for Endpoint Plan 2.

1.1.9.1 Creación de un device group

Desde:

Device groups → Add device group

se configura:

1. **Name**: nombre único del grupo.
2. **Remediation level**: nivel de automatización.
3. **Description**: descripción opcional.
4. **Device matching rules**: condiciones que determinan qué dispositivos pertenecen al grupo.
5. **User access**: grupos de usuarios de Microsoft Entra que pueden acceder al grupo.

El modelo conceptual es:

Matching rule + Remediation level + User access = Device group

1.1.9.2 Device matching rules

La pertenencia a un device group se determina automáticamente mediante reglas basadas principalmente en:

- **Device name**;
- **Domain**;
- **Device tags**;
- **OS platform**.

Por ejemplo:

Domain = contoso.com

+

Tag = Finance

⇓

Dispositivos del dominio contoso.com que además tienen el tag Finance.

Las condiciones de diferentes tipos se combinan conceptualmente mediante:

AND

mientras que múltiples valores dentro del mismo tipo de condición utilizan:

OR

Por ejemplo:

Tag = Madrid OR Tag = Barcelona

Microsoft permite añadir hasta:

10 valores por cada tipo de propiedad

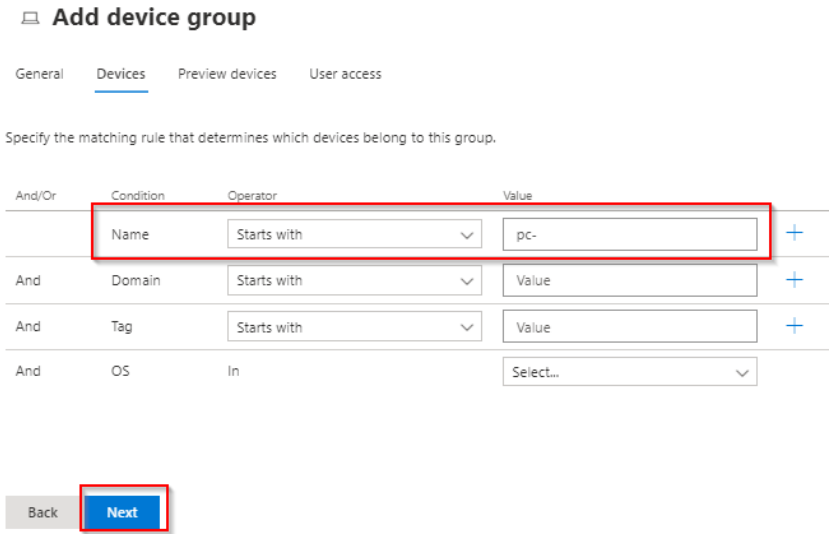


Figure 6: Caption

1.1.9.3 Preview devices

Antes de crear el grupo puede utilizarse:

Show preview

para comprobar qué dispositivos cumplen la regla.
La vista previa muestra hasta:

10 dispositivos

que coinciden con la configuración definida.
Esto permite detectar errores en las reglas antes de crear el grupo.

1.1.9.4 Device group ranking

Cada device group tiene un:

Rank

que determina su prioridad.
La regla más importante es:

Rank 1 = máxima prioridad

Un dispositivo puede coincidir con las condiciones de varios grupos, pero:

solo pertenece al device group de mayor prioridad.

No pertenece simultáneamente a ambos grupos.
Ésta es una diferencia importante respecto a los grupos tradicionales de Microsoft Entra.

1.1.9.5 Promote and demote

Después de crear los grupos puede modificarse su prioridad mediante:

- **Promote**: aumentar la prioridad;
- **Demote**: reducir la prioridad.

1.1.9.6 Ungrouped devices

Los dispositivos que no coinciden con ningún device group se introducen automáticamente en:

Ungrouped devices (default)

Este grupo:

- no puede eliminarse;
- no puede cambiarse de rank;
- sí permite modificar su remediation level;
- permite configurar qué grupos de usuarios de Microsoft Entra pueden acceder a él.

1.1.9.7 Número máximo de grupos

Un tenant puede disponer de hasta:

2,000 device groups

1.1.9.8 User access

Durante la creación del device group se especifican los:

Microsoft Entra user groups

que pueden acceder a los dispositivos contenidos en él.
Sin embargo, esos grupos de usuarios deben tener previamente asignado un:

RBAC role

Por tanto, el acceso efectivo combina:

Role permissions + Microsoft Entra user group + Device group scope

Conceptualmente:

Role → qué puede hacer

Device group → sobre qué dispositivos puede hacerlo

Ésta es una distinción especialmente importante para SC-200.

1.1.9.9 Device group sin User Access

Si no se asigna ningún Microsoft Entra user group a un device group:

> **el device group es accesible para todos los usuarios que tengan acceso al portal.**

Por ello, para limitar realmente el acceso debe configurarse explícitamente:

> **User access**

1.1.9.10 Unified RBAC

Microsoft utiliza actualmente:

> **Microsoft Defender Unified Role-Based Access Control (Unified RBAC)**

como modelo principal de permisos.
La ruta principal es:

> **Permissions → Microsoft Defender XDR → Roles**

Desde allí pueden crearse:

> **Custom roles**

con los permisos necesarios.

1.1.9.11 Permisos importantes en Unified RBAC

Para SC-200 conviene reconocer especialmente:

Permiso	**Función**
Security data basics (Read)	Consultar incidentes, alertas, dispositivos, investigaciones y Advanced Hunting.
Alerts (Manage)	Administrar alertas y determinadas acciones de investigación.
Response (Manage)	Ejecutar acciones de respuesta y aprobar o rechazar remediaciones.
Basic live response (Manage)	Iniciar Live Response y ejecutar acciones básicas.
Advanced live response (Manage)	Ejecutar acciones avanzadas, scripts y cargas durante Live Response.
Authorization (Manage)	Administrar roles y device groups.
Core security settings (Manage)	Administrar configuraciones principales de seguridad.
Detection tuning (Manage)	Administrar custom detections, alert tuning e indicadores.

1.1.9.12 Principio de mínimo privilegio

Microsoft recomienda aplicar:

Least Privilege

de modo que cada analista tenga únicamente:

- los permisos necesarios;
- acceso a los device groups necesarios.

1.1.9.13 Ejemplo de RBAC

Supóngase:

Role: SOC Tier 1

con:

Security data basics = Read

pero sin:

Response = Manage

y dicho role se asigna a:

Entra group = SOC-Madrid

que a su vez tiene acceso únicamente a:

Device group = Madrid

El resultado será:

El SOC puede investigar los dispositivos de Madrid, pero no ejecutar acciones de respuesta que no estén incluidas en su role.

Por tanto:

RBAC Role = acciones permitidas

Device Group = dispositivos accesibles

1.1.9.14 Automation levels

Cada device group tiene asociado un:

Remediation level / Automation level

1.1.9.15 Device groups y alertas

Los device groups afectan también al scope de información que puede consultar un analista.

Un usuario con acceso únicamente a:

Device Group A

tendrá limitado el acceso a información de los dispositivos pertenecientes a ese grupo según sus permisos RBAC.

1.1.9.16 Device groups y email notifications

Los device groups también pueden utilizarse como scope de determinadas:

Email notification rules

Por este motivo, eliminar un device group puede afectar a las reglas de notificación.

1.1.9.17 Device groups vs. Device tags

No deben confundirse:

Device tag

es un atributo asignado a un dispositivo.

Device group

es un conjunto de dispositivos definido mediante reglas y utilizado para RBAC y automation levels.

Un tag puede utilizarse precisamente como condición para crear un device group:

Tag = Finance → Device Group Finance

1.1.9.18 Device groups vs. Microsoft Entra groups

También son conceptos diferentes.

Defender Device Group → agrupa endpoints.

Microsoft Entra User Group → agrupa usuarios/analistas.

Ambos se relacionan mediante RBAC:

Entra User Group

⇓

RBAC Role

⇓

Defender Device Group

De esta forma se determina:

quién puede hacer qué sobre qué dispositivos.

1.1.9.19 Escenarios típicos de examen

Escenario 1: se quieren agrupar automáticamente todos los endpoints Windows del departamento financiero.

Device group con matching rule basada en OS + tag/domain/device name

Escenario 2: un dispositivo coincide con Device Group A de rank 1 y Device Group B de rank 3.

Pertenece únicamente al Device Group A.

Escenario 3: un dispositivo no coincide con ninguna regla.

Ungrouped devices (default)

Escenario 4: un SOC regional debe poder investigar únicamente los endpoints de su región.

RBAC role + Entra user group + regional device group

Escenario 5: un usuario debe consultar alertas, pero no ejecutar acciones de respuesta.

Security data basics (Read)

sin:

Response (Manage)

Escenario 6: un analista debe poder aislar dispositivos y aprobar remediaciones.

Response (Manage)

sobre el scope de device groups correspondiente.
Escenario 7: estaciones de trabajo deben remediarse automáticamente, pero los servidores críticos necesitan mayor intervención humana.

Dos device groups con diferentes automation levels

Escenario 8: se quiere evitar que un grupo concreto de dispositivos ejecute AIR.

No automated response

Escenario 9: un device group no tiene asignado ningún Microsoft Entra user group.

Será accesible para todos los usuarios que tengan acceso al portal.

Escenario 10: dos tags distintos deben incluir dispositivos en el mismo grupo.

Tag A OR Tag B

mientras que diferentes tipos de condiciones deben cumplirse conjuntamente.

1.1.10 Create and configure automation rules in Microsoft Sentinel

Las **Automation Rules** de Microsoft Sentinel permiten automatizar el tratamiento de alertas e incidentes mediante un modelo:

Trigger → Conditions → Actions

Se administran principalmente desde:

Microsoft Sentinel → Configuration → Automation → Automation rules

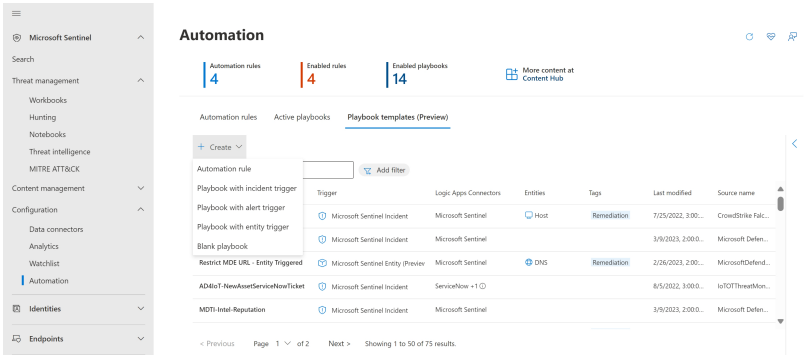


Figure 7: Caption

Desde esta página pueden:

- crearse nuevas reglas;

- habilitarse o deshabilitarse;
- editarse;
- modificarse su orden de ejecución;
- comprobarse las analytics rules a las que afectan.

1.1.10.1 Creación de una Automation Rule

El proceso general es:

1. Seleccionar **Create** → **Automation rule**.
2. Asignar un nombre.
3. Seleccionar el **Trigger**.
4. Definir las **Conditions**.
5. Añadir una o varias **Actions**.
6. Configurar opcionalmente **Rule expiration**.
7. Configurar el **Order**.
8. Seleccionar **Apply**.

1.1.10.2 Triggers

Los tres triggers principales son:

Trigger	**Cuándo se ejecuta**
When incident is created Cuando se crea un nuevo incidente.	
When incident is updated	Cuando cambia alguna propiedad de un incidente existente.
When alert is created	Cuando una analytics rule genera una alerta.

1.1.10.3 Conditions

Las condiciones determinan exactamente sobre qué incidentes o alertas se ejecutará la regla.

Una regla solo ejecuta sus acciones si:

se cumplen todas las condiciones configuradas

Pueden utilizarse propiedades como:

- **Analytics rule name**;
- **Severity**;

- **Status**;
- **Owner**;
- **Provider**;
- **Tactics**;
- **Tags**;
- determinadas propiedades de entidades;
- origen de la actualización mediante **Updated by**.

1.1.10.4 Operadores

Las condiciones pueden utilizar operadores como:

- **Equals**;
- **Does not equal**;
- **Contains**;
- **Does not contain**;
- **Starts with**;
- **Ends with**.

Por ejemplo:

Severity = High

+

Analytics rule name contains "Brute Force"

⇓

Ejecutar acciones únicamente sobre incidentes High relacionados con detecciones de fuerza bruta.

1.1.10.5 Updated by

En reglas basadas en actualización puede utilizarse:

Updated by

para identificar quién o qué modificó el incidente.

1.1.10.6 Actions

Una Automation Rule puede ejecutar directamente acciones sencillas sin necesidad de utilizar un playbook.

Las principales son:

- **Add task**;
- **Change status**;
- **Change severity**;
- **Assign owner**;
- **Add tag**;
- **Run playbook**.

1.1.10.7 Change status

Permite modificar automáticamente el estado del incidente.

Por ejemplo:

New → Active

También puede:

Close

1.1.10.8 Change severity

Permite cambiar automáticamente:

Informational / Low / Medium / High

según las condiciones configuradas.

Por ejemplo:

Incident contiene una cuenta privilegiada

⇓

Set severity = High

1.1.10.9 Assign owner

Permite asignar automáticamente el incidente a:

un usuario o grupo responsable

Esto permite implementar routing automático.

Por ejemplo:

Cloud incident → Cloud SOC

Identity incident → Identity SOC

1.1.10.10 Add tag

Permite añadir etiquetas automáticamente al incidente.

Por ejemplo:

`VIP-user`

`PenTest`

`Ransomware`

1.1.10.11 Add task

Permite añadir automáticamente tareas al incidente.

Por ejemplo:

Task 1: Validate affected account

Task 2: Review sign-in logs

Task 3: Contact account owner

Esto permite estandarizar:

SOC investigation procedures

sin necesidad de construir un playbook.

1.1.10.12 Run playbook

Cuando se necesita realizar una acción más compleja puede añadirse:

Run playbook

Por ejemplo:

- enviar una notificación a Teams;
- crear un ticket en ServiceNow;
- bloquear una IP en un firewall;
- interactuar con Microsoft Entra;
- comunicarse con sistemas externos.

La regla proporciona:

Trigger + Conditions

y el playbook proporciona:

workflow complejo de respuesta

1.1.10.13 Compatibilidad de triggers con playbooks

Debe existir correspondencia entre el trigger de la Automation Rule y el del playbook.

Incident Automation Rule → Incident-trigger playbook

Alert Automation Rule → Alert-trigger playbook

Por tanto, si un playbook aparece:

grayed out

deben comprobarse:

- trigger compatible;
- permisos sobre el playbook.

1.1.10.14 Automation Rule vs. Playbook

Para el examen:

Elemento	Función
Automation Rule	Decide cuándo ejecutar automatización y puede realizar operaciones básicas sobre incidentes.
Playbook	Ejecuta workflows complejos mediante Azure Logic Apps y puede interactuar con sistemas externos.

Por tanto:

Asignar owner → Automation Rule

Añadir tag → Automation Rule

Cambiar severity → Automation Rule

Enviar información a sistema externo → Playbook

1.1.10.15 Order de las Automation Rules

También puede definirse el orden de ejecución entre diferentes Automation Rules.

Cada regla tiene un campo:

Order

Las reglas se ejecutan:

secuencialmente

y no en paralelo.

1.1.10.16 Orden por tipo de trigger

Cada tipo de trigger mantiene su propia cola de ejecución.

1.1.10.17 Rule expiration

Puede configurarse:

Rule expiration

para deshabilitar automáticamente una Automation Rule después de una fecha determinada.

Es especialmente útil para:

- penetration tests;
- mantenimiento programado;
- cambios temporales;
- actividades legítimas que generan incidentes conocidos.

Por ejemplo:

Penetration test del 1 al 7 de octubre

⇓

Cerrar automáticamente determinados incidentes

⇓

Expiration = 7 de octubre

Al alcanzar la fecha:

la regla queda Disabled automáticamente.

1.1.10.18 Crear Automation Rules desde Analytics

También pueden crearse desde el wizard de una:

Analytics rule

en:

Automated response → Automation rules

En este caso la condición correspondiente a esa analytics rule queda ya establecida automáticamente.

Por tanto:

Automation page → regla general o aplicable a varias analytics rules

Analytics rule wizard → automatización específica para esa analytics rule

1.1.10.19 Reglas habilitadas y deshabilitadas

Desde la página Automation puede consultarse el:

Status = Enabled / Disabled

Una regla puede deshabilitarse temporalmente sin necesidad de eliminarla.

1.1.10.20 Escenarios típicos de examen

Escenario 1: todo incidente High generado por una determinada analytics rule debe asignarse automáticamente al equipo Tier 2.

Trigger: When incident is created

Conditions: Severity = High + Analytics rule

Action: Assign owner

Escenario 2: cuando un incidente pase a High severity debe notificarse a un sistema externo.

Trigger: When incident is updated

Condition: Severity changed to High

Action: Run playbook

Escenario 3: se quiere añadir automáticamente una checklist de investigación a determinados incidentes.

Action: Add task

No es obligatorio utilizar un playbook.

Escenario 4: una prueba de penetración generará falsos positivos durante tres días.

Automation Rule que cierre/taggee los incidentes + Rule expiration

Escenario 5: una acción debe ejecutarse sobre cada alerta de una Scheduled analytics rule aunque no se creen incidentes.

Trigger: When alert is created

Escenario 6: un playbook aparece deshabilitado al intentar seleccionarlo. Comprobar:

- compatibilidad del trigger;
- **Microsoft Sentinel Automation Contributor** sobre el Resource Group del playbook.

Escenario 7: una segunda Automation Rule depende del cambio realizado por una primera.

Configurar correctamente Order

porque las reglas se ejecutan secuencialmente.
Escenario 8: se quiere impedir que una regla activada por actualizaciones vuelva a ejecutarse debido a cambios realizados por otra Automation Rule.

Condition: Updated by $\neq$ Automation rule

1.1.11 Create and configure Microsoft Sentinel playbooks

Los **Microsoft Sentinel playbooks** son workflows de respuesta construidos sobre:

Azure Logic Apps

Su finalidad es automatizar acciones de investigación, enriquecimiento y respuesta utilizando conectores hacia Microsoft Sentinel y otros servicios.
La arquitectura básica es:

Trigger $\rightarrow$ Logic / Conditions $\rightarrow$ Actions

A diferencia de las acciones simples de una Automation Rule, un playbook puede implementar workflows complejos, utilizar bucles y condiciones e interactuar con sistemas externos.

1.1.11.1 Ruta de creación

Desde Microsoft Sentinel:

Configuration $\rightarrow$ Automation $\rightarrow$ Create

Los playbooks activos pueden consultarse desde:

Automation $\rightarrow$ Active playbooks

1.1.11.2 Azure Logic Apps

Un playbook es realmente un recurso o workflow de:

Azure Logic Apps

Por ello puede utilizar:

- triggers;
- actions;
- conditions;

- loops;
- switch statements;
- expressions;
- conectores de Microsoft;
- conectores de terceros;
- custom connectors.

Esto permite integrar Sentinel con sistemas como:

- Microsoft Teams;
- Microsoft Entra ID;
- Microsoft Defender;
- ServiceNow;
- firewalls;
- sistemas de ticketing;
- servicios HTTP/REST;
- otros productos externos.

Debe recordarse que Azure Logic Apps es un servicio independiente de Sentinel y puede generar costes adicionales.

1.1.11.3 Tipos de Logic App

Microsoft Sentinel admite actualmente dos tipos:

Tipo	Características
Consumption	Modelo multitenant, ejecución basada en consumo y un workflow por recurso Logic App.
Standard	Modelo single-tenant, permite varios workflows dentro del mismo recurso, mejores capacidades de red, rendimiento y CI/CD.

1.1.11.4 Consumption playbooks

Es el modelo clásico y sencillo para crear playbooks desde Sentinel.

Al seleccionar:

Create → Playbook with incident/alert/entity trigger

Sentinel crea directamente una Logic App Consumption con el trigger correspondiente.

Durante el wizard se definen:

- Subscription;
- Resource Group;
- Playbook name;
- Log Analytics diagnostics, opcionalmente;
- Connections;
- autenticación.

Después se abre:

Logic Apps Designer

para añadir las acciones del workflow.

1.1.11.5 Standard playbooks

Con Logic Apps Standard el flujo es diferente.
Se selecciona:

Create → Blank playbook

y se crea primero un recurso:

Logic App Standard

Después, dentro del recurso:

Workflows → Add

se crea el workflow correspondiente.
Para Microsoft Sentinel debe seleccionarse:

State type = Stateful

porque:

Microsoft Sentinel no admite workflows Stateless como playbooks.

Ésta es una diferencia concreta que puede aparecer en SC-200.

1.1.11.6 Limitaciones de Standard

Dos detalles importantes son:

- los **playbook templates** de Sentinel no pueden utilizarse directamente para crear workflows Standard;
- Sentinel solamente admite workflows Standard **Stateful**.

Además, cuando se utilizan private endpoints debe configurarse correctamente la:

access restriction policy

de Logic Apps; de lo contrario el playbook puede aparecer disponible en Sentinel pero fallar durante su ejecución.

1.1.11.7 Triggers

El Microsoft Sentinel connector proporciona tres triggers principales:

Trigger	Input recibido
Microsoft Sentinel incident	Incidente completo, incluyendo alertas y entidades relacionadas.
Microsoft Sentinel alert	Una alerta individual. Actualmente se encuentra en Preview.
Microsoft Sentinel entity	Una entidad concreta, como una cuenta, IP, host, URL o hash.

1.1.11.8 Incident trigger

Es el trigger:

recomendado por Microsoft para la mayoría de escenarios

porque proporciona un contexto más completo.
Recibe:

- Incident properties;
- Alerts;
- Entities;
- información del workspace.

Por ejemplo:

Incident → Account + IP + Host + Alerts

Esto permite ejecutar una respuesta coordinada utilizando toda la información del incidente.

Si un incidente contiene varias alertas, determinados campos relacionados con las alertas son:

arrays

por lo que Logic Apps puede crear automáticamente:

For each

para procesarlas individualmente.

1.1.11.9 Alert trigger

El trigger:

Microsoft Sentinel alert

recibe una alerta concreta en lugar de un incidente completo.

1.1.11.10 Entity trigger

El trigger:

> **Microsoft Sentinel entity**

permite ejecutar un playbook sobre una entidad específica.
Es especialmente útil para acciones manuales desde:

- investigación de incidentes;
- entity pages;
- threat hunting.

Por ejemplo:

> **IP entity → consultar reputación → bloquear IP en firewall**

o:

> **Account entity → consultar información → deshabilitar usuario**

Los entity-trigger playbooks:

> **no se ejecutan mediante Automation Rules**

sino principalmente de forma manual sobre una entidad.

1.1.11.11 Entity types

Las acciones específicas:

> **Entities – Get ¡entity type¿**

soportan directamente tipos como:

- **IP**;
- **Host**;
- **Account**;
- **URL**;
- **FileHash**.

1.1.11.12 Acciones principales del Microsoft Sentinel connector

Entre las acciones más importantes están:

- **Update Incident**;
- **Add comments to incident**;
- **Get Incident**;
- **Alert – Get Incident**;
- **Entities – Get ¡entity type¿**.

1.1.11.13 Update Incident

Permite modificar propiedades como:

- status;
- severity;
- owner;
- title;
- description;
- tags.

1.1.11.14 Add comments to incident

Permite añadir automáticamente información obtenida durante el workflow.
Ejemplo:

Incident

⇓

Extraer IP

⇓

Consultar Threat Intelligence

⇓

Add comment: "IP classified as malicious"

1.1.11.15 Dynamic content

Las salidas producidas por los triggers y acciones aparecen en Logic Apps como:

Dynamic content

Estos campos pueden reutilizarse en pasos posteriores.

1.1.11.16 Expressions

Cuando el dynamic content no es suficiente puede utilizarse:

Expression editor

para procesar valores mediante funciones de Logic Apps.
Por ejemplo:

- manipular strings;
- trabajar con arrays;
- convertir tipos;
- comprobar valores null;
- realizar cálculos.

Para SC-200 no es necesario memorizar el lenguaje de expresiones completo, pero sí reconocer:

Dynamic content = datos obtenidos de pasos anteriores

Expressions = procesamiento lógico de esos datos

1.1.11.17 Control flow

Logic Apps permite construir workflows complejos utilizando:

- **Condition**;
- **For each**;
- **Switch**;
- ramas paralelas.

Por ejemplo:

Get IP reputation

⇓

Condition: reputation = malicious?

Yes	No
↓	↓
Block IP	Add benign comment

1.1.11.18 For each

For each resulta especialmente importante porque un incidente puede contener:

- múltiples alertas;
- múltiples entidades.

Ejemplo:

Incident contiene 5 IP entities

⇓

For each IP

⇓

Consultar reputación

1.1.11.19 Connectors

Logic Apps utiliza:

Connectors

para comunicarse con otros sistemas.
El playbook utilizará normalmente:

Microsoft Sentinel connector

para interactuar con Sentinel y otros conectores para servicios externos.
Ejemplo:

Microsoft Sentinel connector

⇓

Microsoft Entra ID connector

⇓

Microsoft Teams connector

Un mismo playbook puede utilizar múltiples conectores.

1.1.11.20 Autenticación

Cada conexión utilizada por Logic Apps necesita autenticarse de forma independiente.
Para Microsoft Sentinel pueden utilizarse mecanismos como:

- OAuth;
- Service Principal;
- Managed Identity.

1.1.11.21 Playbook templates

Sentinel dispone de:

Playbook templates

que proporcionan workflows ya desarrollados para casos habituales de SOC.
Se encuentran en:

Automation → Playbook templates

Un template:

NO es un playbook activo

Debe seleccionarse:

Create playbook

para generar una copia desplegable que posteriormente puede personalizarse.
Los templates pueden incluir:

- Logic App;
- API connections;
- parámetros;
- dependencias adicionales.

Algunos requieren previamente:

- otro playbook;
- un custom connector;
- una Azure Function;
- credenciales o API keys.

Los templates están actualmente:

Preview

y no pueden utilizarse directamente para crear workflows Logic Apps Standard.

1.1.11.22 Casos de uso de playbooks

Los escenarios que más conviene asociar a playbooks son:

- **Enrichment**: consultar información externa y añadirla al incidente.
- **Notification**: enviar mensajes por email, Teams u otros canales.
- **Ticketing**: crear o actualizar tickets externos.
- **Containment**: bloquear IP, usuarios u otros IOC.
- **Remediation**: ejecutar una respuesta sobre recursos.
- **Orchestration**: coordinar múltiples sistemas.

1.1.11.23 Monitorización del playbook

Desde:

Automation → Active playbooks

puede comprobarse:

- Status;
- Plan: Standard o Consumption;
- Trigger kind.

Al abrir el recurso en Logic Apps pueden consultarse:

- **Run history**;
- ejecuciones exitosas;
- ejecuciones fallidas;
- inputs;
- outputs;
- error producido en cada acción.

Ésta es la fuente principal para:

troubleshooting de playbooks

1.1.11.24 Problemas habituales

Si un playbook no funciona debe comprobarse principalmente:

1. que esté **Enabled**;
2. que utilice el trigger correcto;
3. que Microsoft Sentinel tenga permiso para ejecutarlo;
4. que las connections estén autenticadas;
5. que la Managed Identity tenga permisos sobre los recursos;
6. que las acciones no estén recibiendo valores null;
7. que no existan errores en Run history.

1.1.11.25 Escenarios típicos de examen

Escenario 1: se necesita un workflow que consulte Threat Intelligence, bloquee una IP y cree un ticket en ServiceNow.

Microsoft Sentinel Playbook / Azure Logic Apps

Escenario 2: el workflow necesita acceder a un recurso privado situado dentro de una Azure VNet.

Logic Apps Standard

Escenario 3: se crea un workflow Standard para Sentinel y debe seleccionarse su state type.

Stateful

Sentinel no admite Stateless para playbooks.

Escenario 4: se quiere automatizar el tratamiento completo de un incidente con sus alertas y entidades.

Microsoft Sentinel incident trigger

Escenario 5: el analista quiere ejecutar manualmente una acción desde una IP encontrada durante threat hunting.

Entity-trigger playbook

Escenario 6: un playbook debe cambiar la severity y añadir un comentario a un incidente.

Update Incident + Add comments to incident

Escenario 7: una Logic App debe modificar incidentes sin almacenar credenciales.

Managed Identity + Microsoft Sentinel Responder

Escenario 8: un analista necesita ejecutar manualmente un playbook pero no editarlo.

Microsoft Sentinel Playbook Operator

Escenario 9: Sentinel debe poder ejecutar automáticamente un playbook que reside en determinado Resource Group.

Microsoft Sentinel Automation Contributor

para la cuenta de servicio de Sentinel sobre dicho Resource Group.
Escenario 10: se necesita crear y modificar una Logic App Consumption.

Logic App Contributor

Escenario 11: se ejecuta un entity playbook desde Hunting y una acción Update Incident falla porque no existe incidente asociado.

Comprobar primero que **Incident ARM ID** $\neq$ **null**.

Escenario 12: se quiere utilizar un workflow preconstruido por Microsoft o la comunidad.

Playbook template $\rightarrow$ **Create playbook** $\rightarrow$ **personalizar**

1.2 Configure the Microsoft Sentinel SIEM and platform

1.2.1 Specify Microsoft Sentinel roles

Microsoft Sentinel utiliza principalmente:

> **Azure Role-Based Access Control (Azure RBAC)**

para controlar el acceso a las funcionalidades del SIEM.
Los roles específicos de Microsoft Sentinel más importantes son:

- **Microsoft Sentinel Reader**
- **Microsoft Sentinel Responder**
- **Microsoft Sentinel Contributor**
- **Microsoft Sentinel Playbook Operator**
- **Microsoft Sentinel Automation Contributor**

Los tres primeros forman una jerarquía muy importante:

> **Reader $\subset$ Responder $\subset$ Contributor**

Es decir:

> **Contributor incluye los permisos de Responder, y Responder incluye los permisos de Reader.**

1.2.1.1 Microsoft Sentinel Reader

El rol:

> **Microsoft Sentinel Reader**

proporciona acceso de lectura a Microsoft Sentinel.
Permite principalmente:

- visualizar incidentes;
- visualizar alertas;
- consultar datos del workspace;
- ejecutar consultas;
- visualizar workbooks;
- visualizar analytics rules;
- visualizar recomendaciones y otros recursos de Sentinel.

No permite:

- modificar incidentes;
- crear o editar analytics rules;
- crear recursos de Sentinel;
- administrar Content Hub.

Por tanto:

Sentinel Reader = View

Un escenario típico sería un auditor o analista que necesita consultar información pero no modificarla.

1.2.1.2 Microsoft Sentinel Responder

El rol:

Microsoft Sentinel Responder

incluye todos los permisos de:

Microsoft Sentinel Reader

y añade capacidad para:

administrar incidentes

Por ejemplo, puede:

- cambiar el estado de un incidente;
- modificar su severidad;
- asignar un owner;
- añadir comentarios;
- añadir tags;
- cerrar incidentes;
- realizar tareas habituales de investigación y triage.

Sin embargo, no puede administrar la configuración general de Sentinel ni crear o editar recursos como analytics rules.

Por tanto:

Sentinel Responder = Reader + Manage incidents

Es el rol típico para:

SOC analysts

que deben investigar y gestionar incidentes pero no administrar la plataforma.

1.2.1.3 Microsoft Sentinel Contributor

El rol:

Microsoft Sentinel Contributor

incluye los permisos de:

Reader + Responder

y añade capacidad para administrar la configuración y recursos de Microsoft Sentinel.

Permite, entre otras operaciones:

- crear y editar analytics rules;
- crear y editar automation rules;
- administrar configuraciones de Sentinel;
- administrar recursos de Sentinel;
- instalar y actualizar soluciones;
- administrar contenido de **Content Hub**;
- administrar incidentes;
- visualizar y consultar datos.

Por tanto:

Sentinel Contributor = Responder + Configure Sentinel

Es el rol habitual para:

Security engineers / Sentinel administrators

1.2.1.4 Jerarquía fundamental

Para SC-200 conviene memorizar:

Rol	**Función principal**
Microsoft Sentinel Reader	Visualizar datos y recursos de Sentinel.
Microsoft Sentinel Responder	Reader + administrar incidentes.
Microsoft Sentinel Contributor	Responder + crear y administrar recursos de Sentinel.

De forma simplificada:

Reader → mirar

Responder → investigar y gestionar incidentes

Contributor → configurar Sentinel

1.2.1.5 Microsoft Sentinel Playbook Operator

El rol:

> **Microsoft Sentinel Playbook Operator**

permite:

- listar playbooks;
- visualizar playbooks;
- ejecutar manualmente playbooks.

No permite:

> **crear o editar playbooks**

porque un playbook es un recurso de Azure Logic Apps.
Por tanto:

Playbook Operator = manually run playbooks

Si el usuario necesita modificar una Logic App deberá disponer además del rol correspondiente de Logic Apps, por ejemplo:

> **Logic App Contributor**

para Logic Apps Consumption.

1.2.1.6 Microsoft Sentinel Automation Contributor

El rol:

> **Microsoft Sentinel Automation Contributor**

tiene una finalidad muy específica:

> **permitir que Microsoft Sentinel ejecute playbooks mediante automatización.**

No está diseñado como un rol normal para analistas.
Microsoft indica específicamente que:

> **no se utiliza para cuentas de usuario.**

1.2.1.7 Playbook Operator vs. Automation Contributor

Esta diferencia es muy importante para SC-200:

Rol	Uso
Microsoft Sentinel Playbook Operator	Un usuario ejecuta manualmente un playbook.
Microsoft Sentinel Automation Contributor	El servicio Microsoft Sentinel ejecuta automáticamente un playbook.

Por tanto:

Manual execution → Playbook Operator

Automation Rule → Automation Contributor

1.2.1.8 Permisos para ejecutar manualmente un playbook sobre un incidente

Para ejecutar manualmente un playbook desde un incidente, el usuario necesita acceso al incidente.

Por ello normalmente necesita:

Microsoft Sentinel Responder

para administrar/acceder al incidente y:

Microsoft Sentinel Playbook Operator

para ejecutar el playbook.
Por tanto:

Responder + Playbook Operator

es una combinación típica para un analista SOC que debe gestionar incidentes y ejecutar playbooks manualmente.

1.2.1.9 Contributor no permite crear playbooks

Una trampa importante es pensar que:

Microsoft Sentinel Contributor

permite crear cualquier recurso utilizado por Sentinel.
No es así.
Los playbooks son:

Azure Logic Apps

y requieren roles propios de Logic Apps.
Por ejemplo:

Logic App Contributor

para crear o modificar Logic Apps Consumption.
Por tanto:

Sentinel Contributor ≠ Logic App Contributor

1.2.1.10 Workbooks

También existe una particularidad con los workbooks.

Los roles Sentinel permiten visualizar workbooks, pero para:

crear o eliminar workbooks

puede ser necesario:

Workbook Contributor

además del rol Sentinel apropiado.
Por tanto, no debe asumirse que:

Sentinel Contributor

proporciona automáticamente todos los permisos necesarios sobre los recursos Azure relacionados con Sentinel.

1.2.1.11 Data connectors

Para conectar determinadas fuentes de datos se necesita:

write permission sobre el workspace

y algunos data connectors requieren permisos adicionales específicos.
Por tanto, Microsoft recomienda revisar:

los requisitos del data connector concreto

porque Sentinel Contributor por sí solo puede no cubrir todas las operaciones necesarias sobre el servicio origen.

1.2.1.12 Content Hub

Para:

instalar o actualizar soluciones desde Content Hub

se utiliza:

Microsoft Sentinel Contributor

y Microsoft recomienda asignarlo a nivel de:

Resource Group

que contiene el workspace.

1.2.1.13 Scope de los roles

Azure RBAC permite asignar los roles a distintos ámbitos:

- Subscription;
- Resource Group;
- Resource.

Microsoft recomienda generalmente asignar los roles Sentinel al:

Resource Group que contiene el Microsoft Sentinel workspace

porque así el rol puede aplicarse también correctamente a los recursos relacionados.
Asignar un rol únicamente al workspace proporciona un scope más reducido, pero puede requerir asignaciones adicionales sobre:

- SecurityInsights solution;
- playbooks;
- otros recursos asociados.

Para SC-200:

Microsoft recomienda Resource Group scope para los roles Sentinel

1.2.1.14 Azure roles generales

También existen roles generales de Azure como:

- **Reader**;
- **Contributor**;
- **Owner**.

Estos roles tienen un alcance mucho mayor que los específicos de Sentinel.
Por ejemplo:

Azure Contributor

puede administrar una gran variedad de recursos Azure, no solamente Sentinel.
Por ello, para un analista SOC se prefieren:

Microsoft Sentinel Reader / Responder / Contributor

porque aplican:

least privilege

de forma más precisa.

1.2.1.15 Roles de Log Analytics

Pueden existir también:

- **Log Analytics Reader**;
- **Log Analytics Contributor**.

Estos roles proporcionan permisos sobre:

Log Analytics workspace

y no deben confundirse con los roles específicos de Microsoft Sentinel.
Para tareas SOC debe preferirse normalmente:

Microsoft Sentinel roles

salvo que sea necesario administrar específicamente funcionalidades del workspace de Log Analytics.

1.2.1.16 Microsoft Sentinel Data Lake

Para el SIEM tradicional, Microsoft Sentinel utiliza:

Azure RBAC

El nuevo:

Microsoft Sentinel Data Lake

incorpora además permisos administrados mediante:

Microsoft Entra ID RBAC

para determinadas capacidades del data lake.
Para este objetivo del SC-200, lo fundamental continúa siendo reconocer los roles Azure RBAC específicos de Sentinel y seleccionar el mínimo necesario para cada tarea.

1.2.1.17 Resumen de roles

Rol	**Función principal**
Microsoft Sentinel Reader	Visualizar datos, incidentes y recursos.
Microsoft Sentinel Responder	Reader + administrar incidentes.
Microsoft Sentinel Contributor	Responder + crear y administrar recursos de Sentinel y Content Hub.
Microsoft Sentinel Playbook Operator	Ejecutar playbooks manualmente.
Microsoft Sentinel Automation Contributor	Permitir que Sentinel ejecute playbooks automáticamente.
Logic App Contributor	Crear y editar Logic Apps/playbooks Consumption.
Workbook Contributor	Crear y eliminar workbooks.

1.2.1.18 Escenarios típicos de examen

Escenario 1: un auditor necesita consultar incidentes, consultas y workbooks pero nunca modificarlos.

Microsoft Sentinel Reader

Escenario 2: un analista SOC debe investigar, asignar y cerrar incidentes, pero no modificar analytics rules.

Microsoft Sentinel Responder

Escenario 3: un security engineer debe crear analytics rules, automation rules y administrar soluciones de Content Hub.

Microsoft Sentinel Contributor

Escenario 4: un analista necesita ejecutar manualmente un playbook desde un incidente.

Microsoft Sentinel Responder + Microsoft Sentinel Playbook Operator

Escenario 5: Microsoft Sentinel debe ejecutar automáticamente un playbook mediante una Automation Rule.

Microsoft Sentinel Automation Contributor

para la cuenta de servicio de Sentinel sobre el Resource Group del playbook.
Escenario 6: un usuario debe modificar el workflow de un playbook Consumption.

Logic App Contributor

Escenario 7: un usuario debe crear o eliminar workbooks.

Workbook Contributor

además del acceso necesario a Sentinel.
Escenario 8: se necesita instalar soluciones desde Content Hub.

Microsoft Sentinel Contributor

preferiblemente asignado a nivel del Resource Group.

1.2.2 Manage data retention for XDR and Microsoft Sentinel tables, including Analytics, Data lake, and XDR tiers

Microsoft Defender XDR y Microsoft Sentinel permiten distribuir los datos entre distintos **data tiers** según la velocidad de acceso, las funcionalidades necesarias y el periodo de retención.

Para SC-200 deben distinguirse tres conceptos:

- **XDR default tier**: telemetría de Defender XDR disponible para Advanced Hunting durante 30 días.
- **Analytics tier**: datos 'hot" disponibles para detección, hunting y análisis en tiempo real.
- **Data Lake tier**: almacenamiento 'cold" de bajo coste para retención histórica.

1.2.2.1 Comparación fundamental

Tier	Retención	Uso principal
XDR default	30 días	Advanced Hunting de Defender XDR.
Analytics	30 días–2 años	Alertas, analytics rules, hunting, workbooks y consultas rápidas.
Data Lake	30 días–12 años	Histórico, forense, cumplimiento y grandes volúmenes de datos.

1.2.2.2 XDR default tier

Microsoft Defender XDR mantiene por defecto los datos utilizados para:

Advanced Hunting

durante:

30 días

Esta retención está incluida en la licencia de Defender XDR.
Por defecto, estos datos:

no se ingieren en el workspace de Microsoft Sentinel

ni en Analytics ni en Data Lake.
Por tanto:

XDR Advanced Hunting por defecto = últimos 30 días

1.2.2.3 Extender la retención de XDR

Si se necesita conservar una tabla XDR compatible durante más de 30 días, puede integrarse con Microsoft Sentinel.

Al configurar:

Analytics retention > 30 días

la tabla se crea en el workspace de Sentinel y sus datos se ingieren en:

Analytics tier

y se reflejan también en:

Data Lake

Para datos XDR:

- primeros **30 días**: incluidos en XDR;
- **31–90 días**: se aplican costes de ingestión de Sentinel, pero no costes adicionales de almacenamiento Analytics;
- más de **90 días en Analytics**: también se aplican costes de almacenamiento.

Esto da lugar a una regla muy útil:

XDR = 30 días incluidos; Sentinel permite extender la retención

1.2.2.4 Analytics tier

El **Analytics tier** almacena los datos que deben estar disponibles inmediatamente para las funciones operativas del SOC.

Los datos pueden utilizarse directamente en:

- analytics rules;
- alerting;
- threat hunting;
- workbooks;
- Advanced Hunting;
- playbooks y demás funcionalidades en tiempo real.

La retención Analytics puede configurarse desde:

30 días hasta 2 años

Microsoft permite mantener hasta:

90 días de retención Analytics para determinadas Microsoft Sentinel solution tables sin coste adicional de almacenamiento.

La idea para el examen es:

Analytics = hot data + detección y análisis en tiempo real

1.2.2.5 Analytics retention vs. Total retention

Una tabla en Analytics tiene dos conceptos distintos:

- **Analytics retention**: cuánto tiempo permanece disponible como dato hot.
- **Total retention**: cuánto tiempo se conserva en total incluyendo Data Lake.

Ejemplo:

Analytics retention = 90 días

Total retention = 1 año

significa:

0–90 días → **Analytics tier**

90 días–1 año → **Data Lake**

Por tanto:

Total retention puede ser mayor que Analytics retention

1.2.2.6 Limitación fundamental del Data Lake

Los datos almacenados exclusivamente en Data Lake:

no participan directamente en las funcionalidades de análisis en tiempo real.

1.2.2.7 Consultar datos del Data Lake

Los datos históricos del Data Lake pueden analizarse principalmente mediante:

KQL jobs

que permiten ejecutar consultas KQL sobre datos históricos.
También pueden utilizarse:

- Search jobs;
- Summary rules;
- notebooks;
- Spark jobs.

Para SC-200, la asociación principal es:

Data Lake + consulta histórica compleja → KQL job

Los KQL jobs pueden consultar hasta:

12 años de datos

y pueden promover resultados nuevamente hacia:

Analytics tier

para realizar investigaciones posteriores.

1.2.2.8 Escenarios típicos de examen

Escenario 1: el SOC necesita ejecutar analytics rules y hunting sobre una tabla.

Analytics tier

Escenario 2: deben conservarse logs durante siete años por requisitos regulatorios, pero no se necesitan para alertas en tiempo real.

Data Lake tier

Escenario 3: se necesitan investigar eventos XDR de hace 60 días mediante capacidades de Sentinel.

Extender la tabla XDR hacia Analytics tier de Sentinel

Escenario 4: se necesitan consultar varios años de logs almacenados en Data Lake utilizando KQL.

KQL job

Escenario 5: se mueve una tabla de Analytics a Data Lake y dejan de ejecutarse analytics rules que utilizan esa tabla.

Comportamiento esperado: Data Lake no soporta análisis/detección en tiempo real.

1.2.3 Create and configure Microsoft Sentinel workbooks

Los **Microsoft Sentinel workbooks** son dashboards interactivos basados en:

Azure Monitor Workbooks

y se utilizan para visualizar, explorar y monitorizar datos de seguridad.
Para SC-200, lo importante es saber:

- crear un workbook desde cero o desde una plantilla;
- añadir consultas KQL;
- configurar visualizaciones;
- utilizar parámetros;
- conocer los permisos necesarios.

1.2.3.1 Ruta

En Microsoft Sentinel:

Threat management → Workbooks

Desde esta página pueden consultarse:

- **Templates**;
- workbooks guardados.

1.2.3.2 Workbook template vs. Workbook

Microsoft proporciona numerosas:

Workbook templates

a través de soluciones instaladas desde:

Content Hub

Una template:

no es todavía un workbook guardado.

Al abrirla puede visualizarse y probarse, pero para crear una copia persistente debe seleccionarse:

Save

Esto crea un recurso Azure Workbook basado en la plantilla.
Por tanto:

Template → Save → Workbook

La plantilla original permanece sin modificar.

1.2.3.3 Required data types

Muchos templates dependen de determinadas fuentes de datos.
Antes de utilizar un workbook debe comprobarse:

Required data types

Si Sentinel no está ingiriendo esos datos:

el workbook puede aparecer vacío aunque esté correctamente configurado.

Ésta es una causa habitual de troubleshooting.

1.2.3.4 Crear un workbook desde cero

También puede crearse un workbook personalizado.

Desde:

Workbooks → Add workbook / New

se abre un workbook vacío en modo edición.

Los elementos más importantes que pueden añadirse son:

- **Query**;
- **Parameters**;
- **Text**;
- visualizaciones;
- links;
- groups.

Para SC-200, los dos elementos más importantes son:

Query + Parameters

1.2.3.5 Queries

El elemento:

Add query

permite obtener datos para el workbook.

En Microsoft Sentinel normalmente se utiliza:

Logs + KQL

sobre las tablas disponibles en el workspace.

Por ejemplo:

```
SecurityIncident
| summarize Incidents=count() by Severity
```

La consulta devuelve los datos que posteriormente se muestran mediante una visualización.

Conceptualmente:

KQL query → Result set → Visualization

1.2.3.6 Visualizations

El resultado de una consulta puede representarse mediante diferentes formatos.

1.2.3.7 Parameters

Los **parameters** permiten convertir un workbook estático en un informe interactivo.
Un parámetro puede modificar dinámicamente:

- una consulta;
- el periodo temporal;
- el recurso;
- un filtro;
- una visualización.

Entre los tipos disponibles están:

- **Time**;
- **Drop down**;
- **Text**;
- **Options group**;
- **Resource**;
- **Subscription**;
- **Multi-value**.

Para SC-200, el más importante es:

Time range parameter

1.2.3.8 Time range parameter

Permite seleccionar dinámicamente periodos como:

- Last hour;
- Last 24 hours;
- Last 7 days;
- Custom time range.

1.2.3.9 Guardar un workbook

Cuando se guarda un workbook se crea:

un recurso Azure Workbook

asociado al entorno de Sentinel.
El workbook almacena principalmente:

- definición;
- queries;
- parámetros;
- visualizaciones;
- diseño.

No almacena una copia independiente de todos los datos mostrados.
Cada vez que se utiliza:

las consultas obtienen los datos desde sus fuentes correspondientes.

1.2.3.10 Advanced Editor

Un workbook también dispone de:

Advanced Editor

que permite visualizar y modificar la definición:

JSON

del workbook.

1.2.3.11 Workbooks y Content Hub

Muchos data connectors y soluciones de Sentinel incluyen:

Workbook templates

que se instalan mediante:

Content Hub

Por ejemplo, una solución puede incluir:

- Data Connector;
- Analytics Rules;
- Hunting Queries;
- Workbook.

Microsoft recomienda utilizar los workbooks asociados a las fuentes de datos que se están ingiriendo.

1.2.3.12 Escenarios típicos de examen

Escenario 1: se necesita un dashboard visual de incidentes por severidad, usuario y periodo temporal.

Microsoft Sentinel Workbook

Escenario 2: se dispone de un workbook preconstruido dentro de una solución de Content Hub.

Abrir template → comprobar Required data types → Save

Escenario 3: se quiere cambiar dinámicamente el periodo temporal de todas las gráficas del workbook.

Time range parameter

Escenario 4: se quiere seleccionar una severity desde un dropdown y actualizar varias consultas.

Parameter

Escenario 5: un workbook aparece vacío aunque el template se ha instalado correctamente.

Comprobar Required data types y data connectors.

Escenario 6: se necesita modificar directamente la definición completa del workbook.

Advanced Editor → JSON

Escenario 7: un usuario puede abrir el workbook pero algunas consultas no devuelven datos.

Comprobar permisos sobre la fuente de datos / Log Analytics workspace.

Escenario 8: se necesita crear o eliminar un workbook.

Workbook Contributor + rol Sentinel apropiado

1.2.4 Optimize the Microsoft Sentinel platform, including SOC optimization recommendations

SOC optimization proporciona recomendaciones automáticas para mejorar Microsoft Sentinel equilibrando dos objetivos:

Security coverage + Cost efficiency

Analiza principalmente:

- los datos ingeridos;
- el uso de las tablas;
- las analytics rules habilitadas;
- la cobertura frente a amenazas y MITRE ATT&CK.

Las recomendaciones se recalculan:

cada 24 horas

1.2.4.1 Acceso

En el Microsoft Defender portal se accede a:

SOC optimization

El dashboard muestra métricas sobre:

- valor obtenido mediante optimizaciones recientes;
- volumen de datos ingerido en los últimos 90 días;
- cobertura frente a amenazas;
- recomendaciones Active, Completed y Dismissed.

1.2.4.2 Tipos de recomendaciones

Para SC-200 deben distinguirse principalmente:

Tipo	Objetivo
Data value	Reducir costes o aumentar el valor de los datos ya ingeridos.
Threat-based coverage	Detectar carencias de fuentes de datos o detecciones frente a amenazas concretas.
Risk-based	Detectar carencias de cobertura frente a riesgos empresariales.
AI MITRE ATT&CK tagging	Recomendar tácticas y técnicas MITRE ATT&CK para analytics rules.
Similar organizations	Recomendar fuentes de datos utilizadas por organizaciones similares.

1.2.4.3 Excepción importante

SOC optimization no recomienda reducir la ingestión de una tabla cuando ésta está siendo utilizada para:

- **UEBA**;
- una **Threat Intelligence matching analytics rule**.

Aunque aparentemente tenga poco uso en otras detecciones.

1.2.4.4 Unused columns

SOC optimization también puede identificar:

columnas ingeridas que no están siendo utilizadas

y recomendar dejar de ingerirlas.
Esta capacidad se encuentra actualmente en:

Preview

Su finalidad es reducir:

ingestion cost + unnecessary data

sin eliminar completamente la tabla.

1.2.4.5 Threat-based coverage recommendations

Las recomendaciones:

Threat-based

comparan las fuentes de datos y detecciones existentes con las necesarias para cubrir determinados escenarios de ataque.
Consideran tanto:

- detecciones predefinidas;
- detecciones creadas por el usuario.

Deben memorizarse tres situaciones:

Situación	**Acción recomendada**
Existen datos pero faltan detecciones	Habilitar analytics rule templates.
Existen detecciones pero faltan datos	Conectar nuevas data sources.
No existen datos ni detecciones	Instalar solución/conectar data sources y detecciones.

Esta asociación es especialmente importante para SC-200:

Data exists + no detection → Analytics rules

Detection exists + no data → Data connector

1.2.4.6 Similar organizations

Sentinel puede utilizar machine learning para identificar fuentes de datos utilizadas por organizaciones con:

- patrones de ingestión similares;
- perfiles sectoriales similares.

Si detecta una fuente relevante que no está presente en el workspace:

recomienda conectar dicha data source y las detecciones asociadas.

No todos los workspaces reciben estas recomendaciones.
El análisis se basa en:

metadata y características organizativas

y no en el contenido de los logs de otras organizaciones.

1.2.4.7 Estados

Las optimizaciones pueden aparecer como:

- **Active**;
- **In progress**;
- **Completed**;
- **Dismissed**.

Por defecto:

Status = Active

Una recomendación puede marcarse manualmente como completada, pero Sentinel también puede completarla automáticamente si detecta que el cambio necesario ya se ha realizado.
Por ejemplo:

Unused table recommendation

⇓

Se habilita una analytics rule que utiliza esa tabla

⇓

Optimization automatically completed

1.2.4.8 Optimización de costes

Además de las recomendaciones SOC, las principales decisiones de optimización de coste de Sentinel son:

- eliminar o filtrar datos sin valor de seguridad;
- utilizar un plan/tier más económico para datos de bajo uso;
- utilizar Data Lake para histórico;
- ajustar el **commitment tier** al volumen habitual de ingestión;
- aplicar transformations para filtrar filas o columnas innecesarias antes de almacenarlas.

El modelo de pricing del Analytics tier puede ser:

Pay-as-you-go

o:

Commitment tier

Los commitment tiers comienzan en:

100 GB/day

y pueden reducir el coste cuando existe un volumen de ingestión elevado y relativamente predecible.

1.2.4.9 SOC optimization vs. Analytics rule tuning

No deben confundirse dos funcionalidades diferentes.

Función	Objetivo
SOC optimization	Optimizar cobertura, fuentes de datos y costes del workspace.
Analytics rule tuning recommendations	Afinar una regla concreta para reducir falsos positivos y mejorar su eficacia.

1.2.4.10 Escenarios típicos de examen

Escenario 1: Sentinel ingiere una tabla facturable que no ha sido utilizada por ninguna detección durante los últimos 30 días.

Data value optimization

Puede recomendar habilitar analytics rules o reducir el coste de la tabla.

Escenario 2: existen logs adecuados para detectar ransomware, pero ninguna detección utiliza esos datos.

Threat-based optimization → habilitar analytics rule templates

Escenario 3: una analytics rule está habilitada pero la fuente de datos necesaria no está conectada.

Conectar la data source correspondiente

Escenario 4: se quiere analizar qué técnicas de un escenario de ataque no están cubiertas.

Threat-based SOC optimization + MITRE ATT&CK view

Escenario 5: una tabla no tiene valor para detección en tiempo real pero debe conservarse.

Moverla a un tier/plan de menor coste o almacenamiento histórico

1.3 Ingest data into the Microsoft Sentinel SIEM and platform

1.3.1 Select data connectors based on data source requirements, including Windows logs and security events

Microsoft Sentinel utiliza **data connectors** para ingerir datos desde productos Microsoft, servicios Azure, endpoints, dispositivos de red y soluciones de terceros.

La ruta principal es:

Microsoft Sentinel → Configuration → Data connectors

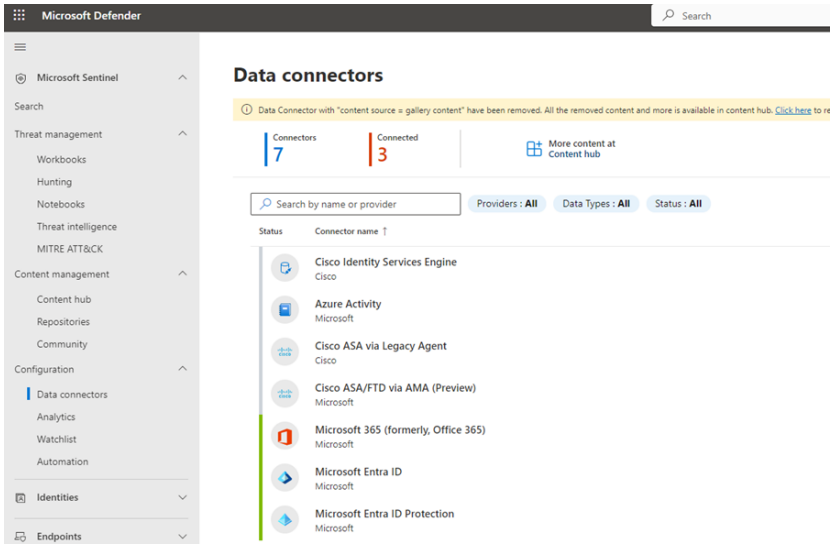


Figure 8: Caption

En muchos casos el conector se instala previamente mediante:

Content Hub → Solution → Install

Para SC-200, la clave es seleccionar el conector según:

- tipo de fuente;
- formato de los logs;
- ubicación de la fuente;
- necesidad de filtrar eventos antes de ingerirlos;
- tabla de Sentinel que necesita utilizarse.

1.3.1.1 Selección del conector

Fuente	Conector recomendado	Tabla típica
Windows Security Events	Windows Security Events via AMA	`SecurityEvent`
Eventos centralizados mediante WEF/WEC	Windows Forwarded Events	`WindowsEvent`
Linux / Unix	Syslog via AMA	`Syslog`
Firewall, IDS/IPS u otro appliance que envía CEF	Common Event Format (CEF) via AMA	`CommonSecurityLog`
Aplicación que escribe logs en archivos de texto	Custom Logs via AMA	Tabla custom
Servicio Microsoft/Azure compatible	Connector nativo/API/service-to-service	Depende del servicio
Producto SaaS con REST API y sin conector adecuado	CCF / API / Azure Functions	Tabla específica/custom

1.3.1.2 Windows Security Events via AMA

Para recopilar directamente eventos de seguridad desde equipos Windows debe utilizarse preferentemente:

Windows Security Events via AMA

AMA significa:

Azure Monitor Agent

y es el agente actual recomendado por Microsoft.
El flujo es:

Windows host

⇓

Azure Monitor Agent

⇓

Data Collection Rule (DCR)

⇓

Microsoft Sentinel

⇓

`SecurityEvent`

Esta tabla es especialmente importante porque muchas:

built-in analytics rules

de Windows consultan directamente:

`SecurityEvent`

1.3.1.3 Data Collection Rules

Los conectores basados en AMA utilizan:

Data Collection Rules (DCR)

para determinar:

- qué dispositivos recopilan datos;
- qué eventos se recopilan;
- qué filtros se aplican;
- a qué destino se envían.

Una ventaja fundamental es:

filtrar en origen antes de ingerir los datos

Las DCR pueden reutilizarse y aplicarse a múltiples dispositivos.

1.3.1.4 Windows Security Event sets

El conector Windows Security Events via AMA permite seleccionar cuatro conjuntos principales:

Event set	Comportamiento
All	Recopila todos los eventos de Security y AppLocker. Mayor volumen.
Common	Mantiene un audit trail amplio reduciendo el volumen frente a All.
Minimal	Recopila principalmente eventos con valor para detección de amenazas. Menor volumen.
Custom	Permite seleccionar eventos concretos mediante consultas XPath.

Para SC-200:

Custom → XPath

Ejemplo conceptual:

La organización solamente necesita Event ID 4624, 4625 y 4688.

⇒

Custom event set mediante DCR/XPath

1.3.1.5 Event IDs importantes

No es necesario memorizar muchos Event IDs, pero conviene reconocer:

- **4624**: successful logon;
- **4625**: failed logon;
- **4688**: process creation.

Son eventos especialmente habituales en consultas y escenarios de detección.

1.3.1.6 Equipos fuera de Azure

Si el dispositivo Windows:

- está on-premises;
- es una VM fuera de Azure;
- está en otro cloud;

debe habilitarse primero:

Azure Arc

para que Azure pueda administrar e instalar AMA sobre el equipo.
Por tanto:

Non-Azure Windows server → Azure Arc → AMA → DCR

1.3.1.7 Windows Event Forwarding

Si la organización ya utiliza:

Windows Event Forwarding (WEF)

varios equipos Windows envían sus eventos hacia uno o varios:

Windows Event Collectors (WEC)

En este caso puede utilizarse:

Windows Forwarded Events connector

instalando AMA en el:

WEC

El flujo es:

Windows endpoints

⇓

WEF

⇓

WEC + AMA

⇓

Microsoft Sentinel

⇓

`WindowsEvent`

1.3.1.8 Cuándo elegir AMA directo o WEF

Necesidad	**Opción**
Recopilar Security Events directamente de equipos Windows	Windows Security Events via AMA
Necesitar compatibilidad directa con analytics rules basadas en `SecurityEvent`	Windows Security Events via AMA
La organización ya centraliza eventos mediante WEF/WEC	Windows Forwarded Events
Centralizar múltiples Windows Event Logs antes de enviarlos a Sentinel	Windows Forwarded Events

1.3.1.9 CEF via AMA

Muchos productos de seguridad de terceros utilizan:

Common Event Format (CEF)

sobre Syslog.
Ejemplos:

- firewalls;
- IDS/IPS;
- VPN;
- proxies;
- appliances de seguridad.

Para ellos se utiliza:

Common Event Format (CEF) via AMA

Los eventos normalizados se almacenan en:

`CommonSecurityLog`

1.3.1.10 Conectores API/service-to-service

Para servicios cloud como Azure y Microsoft 365 debe priorizarse, cuando exista:

built-in data connector

Estos conectores pueden utilizar:

- integración service-to-service;
- APIs;
- diagnostic settings.

No requieren necesariamente instalar agentes en endpoints.
Ejemplos conceptuales:

Microsoft Entra ID → native connector

Microsoft 365 service → native/API connector

Azure resource logs → diagnostic settings / native connector

La regla para el examen es:

Si existe un conector nativo soportado, utilizarlo antes que desarrollar uno custom.

1.3.1.11 Custom connectors

Si no existe un conector adecuado pueden utilizarse mecanismos como:

- Codeless Connector Framework (CCF);
- Logs Ingestion API;
- Azure Functions;
- Logic Apps;
- AMA para determinados logs locales.

Para fuentes SaaS accesibles mediante REST API, Microsoft recomienda especialmente:

> **Codeless Connector Framework**

cuando sea compatible.

1.3.1.12 Escenarios típicos de examen

Escenario 1: recopilar eventos de inicio de sesión y creación de procesos directamente desde servidores Windows.

> **Windows Security Events via AMA**

Escenario 2: una built-in analytics rule consulta `SecurityEvent`.

> **Preferir Windows Security Events via AMA**

Escenario 3: cientos de endpoints ya utilizan Windows Event Forwarding hacia un servidor central.

> **Windows Forwarded Events + AMA en el WEC**

Escenario 4: eventos enviados mediante Windows Forwarded Events no activan una built-in analytics rule.

> Comprobar si la regla consulta `SecurityEvent` mientras los eventos están en `WindowsEvent`.

Escenario 5: un servidor Windows on-premises debe enviar Security Events directamente a Sentinel.

> **Azure Arc + AMA + Windows Security Events via AMA**

Escenario 6: se quiere ingerir únicamente determinados Windows Event IDs.

> **Custom event set + DCR + XPath**

Escenario 7: un firewall soporta CEF sobre Syslog.

Common Event Format (CEF) via AMA

Escenario 8: un Linux server genera Syslog estándar.

Syslog via AMA

Escenario 9: una aplicación escribe logs propios en archivos de texto.

Custom Logs via AMA

1.3.2 Configure collection of Windows Security events by using Windows Security Events via AMA, including data collection rules

La configuración de Windows Security Events via AMA se basa fundamentalmente en crear una:

Data Collection Rule (DCR)

que especifica:

qué equipos + qué eventos + qué workspace

1.3.2.1 Creación de la DCR

Desde:

Microsoft Sentinel → Configuration → Data connectors

se abre:

Windows Security Events via AMA

y se selecciona:

Open connector page → Add data collection rule

El wizard consta fundamentalmente de:

1. **Basics**: nombre, subscription y Resource Group de la DCR.
2. **Resources**: máquinas sobre las que se aplicará.
3. **Collect**: eventos que deben recopilarse.
4. **Review + create**.

La DCR no tiene que encontrarse en el mismo Resource Group que las máquinas monitorizadas.

Puede incluso estar en otra subscription siempre que:

los recursos pertenezcan al mismo tenant.

1.3.2.2 Seleccionar los eventos

En la sección:

Collect

se selecciona uno de los conjuntos:

- **All**;
- **Common**;
- **Minimal**;
- **Custom**.

La diferencia práctica que debe recordarse es:

Set	**Cuándo utilizarlo**
All	Se necesita el máximo nivel de auditoría y se acepta un volumen elevado de ingestión.
Common	Se necesita un audit trail amplio reduciendo el volumen respecto a All.
Minimal	Se priorizan eventos con valor para detección de amenazas y menor volumen.
Custom	Se necesitan Event IDs o canales concretos definidos mediante XPath.

1.3.2.3 Common vs. Minimal

Common mantiene un:

audit trail amplio

incluyendo eventos que pueden ser útiles para auditoría aunque no sean especialmente relevantes para detección.

Por ejemplo, incluye:

4634 – Logoff

Minimal está más orientado a:

security detection

y elimina eventos de mucho volumen y menor valor para detectar una intrusión.

Por ejemplo, incluye:

4624 – Successful logon

4625 – Failed logon

4688 – Process creation

pero no incluye el audit trail completo de Common.
Para el examen:

Common = auditing

Minimal = threat detection + menor volumen

1.3.2.4 Custom collection

Si los conjuntos anteriores recopilan demasiados eventos puede seleccionarse:

Custom

y utilizar:

XPath queries

para seleccionar exactamente los eventos que deben recopilarse.
Ejemplo sencillo para recopilar únicamente failed logons:

```
Security!*[System[(EventID=4625)]]
```

Para varios Event IDs:

```
Security!*[System[
(EventID=4624 or
EventID=4625 or
EventID=4688)
]]
```

Esto permite realizar el filtrado:

antes de que los eventos sean ingeridos

y reducir el coste.

1.3.2.5 Sintaxis XPath

AMA soporta:

XPath 1.0

para estas consultas.
La estructura que conviene reconocer es:

```
LogName!*[System[condition]]
```

Por ejemplo:

```
Security!*[System[EventID=4625]]
```

significa:

Security log + Event ID 4625

No es necesario dominar XPath para SC-200, pero sí reconocer que:

Custom Windows event filtering en una DCR = XPath

1.3.2.6 Límites de expresiones XPath

En la interfaz pueden configurarse:

hasta 20 expresiones por cuadro

y:

hasta 100 cuadros por DCR.

1.3.2.7 Escenarios típicos de examen

Escenario 1: se necesita recopilar únicamente los Event IDs 4624, 4625 y 4688.

Custom event set + XPath en la DCR

Escenario 2: se necesita conservar un audit trail amplio, pero evitar el volumen de All.

Common

Escenario 3: el objetivo principal es threat detection minimizando ingestión.

Minimal

Escenario 4: se añade el Event ID 4688 a la DCR, pero nunca aparece.

Comprobar primero que la Audit Policy de Windows esté generando el evento.

Escenario 5: se quiere reducir el coste eliminando eventos innecesarios antes de enviarlos a Sentinel.

Filtrado en DCR mediante XPath

Escenario 6: una consulta XPath devuelve "No events were found that match the specified selection criteria".

La consulta puede ser válida; simplemente no existen eventos coincidentes actualmente.

Escenario 7: la misma configuración de recopilación debe aplicarse a cientos de servidores.

Una DCR reutilizada y asociada a múltiples Resources.

1.3.3 Plan and configure collection of Windows Security events by using Windows Event Forwarding (WEF)

Windows Event Forwarding (WEF) permite centralizar eventos de múltiples equipos Windows en uno o varios:

Windows Event Collectors (WEC)

utilizando:

WinRM / WS-Management

La arquitectura que debe recordarse es:

Windows Event Sources

⇓

WEF / WinRM

⇓

Windows Event Collector (WEC)

⇓

ForwardedEvents

⇓

Microsoft Sentinel

1.3.3.1 Tipos de suscripción

WEF dispone de dos modelos:

Tipo	Funcionamiento
Source-initiated	Los equipos origen descubren el WEC mediante configuración, normalmente GPO, y solicitan las suscripciones correspondientes.
Collector-initiated	El WEC contiene explícitamente la lista de equipos origen desde los que debe recopilar eventos.

1.3.3.2 Configuración del WEC

En el servidor que actuará como collector debe habilitarse:

Windows Event Collector service

El comando fundamental es:

```
wecutil qc /q
```

También debe estar disponible WinRM:

```
winrm qc -q
```

La suscripción puede crearse desde:

Event Viewer → Subscriptions

1.3.3.3 Configuración de los clientes Source-initiated

En entornos de dominio, la configuración habitual se distribuye mediante:

Group Policy

en:

Computer Configuration → Administrative Templates → Windows Components → Event Forwarding

La política fundamental es:

Configure target Subscription Manager

También denominada:

SubscriptionManager

Aquí se especifica la dirección del WEC.
Con HTTP, el formato conceptual es:

```
Server=http://WEC-FQDN:5985/wsman/SubscriptionManager/WEC
```

Para HTTPS se utiliza normalmente:

```
Server=https://WEC-FQDN:5986/wsman/SubscriptionManager/WEC
```

Por tanto:

WinRM HTTP = 5985

WinRM HTTPS = 5986

1.3.3.4 Forwarding del Security Log

Para permitir que WEF acceda al:

Windows Security log

Microsoft indica que debe añadirse:

NETWORK SERVICE

al grupo:

Event Log Readers

en los equipos origen.

Si faltan estos permisos, otros logs pueden reenviarse correctamente mientras los eventos de Security no aparecen.

1.3.3.5 Subscription filter

Dentro de la suscripción se seleccionan los eventos que deben reenviarse.

Puede filtrarse por:

- event log;
- event source;
- Event ID;
- level;
- keywords;
- otras propiedades del evento.

1.3.3.6 Equipos fuera del dominio

Cuando source y collector no pertenecen al mismo dominio o no existe una relación de confianza adecuada, Microsoft admite:

WEF sobre HTTPS

mediante certificados.

En este escenario se necesitan:

- certificado Server Authentication en el WEC;
- certificado Client Authentication en los sources;
- WinRM HTTPS;
- puerto TCP 5986;
- configuración de certificate mapping.

Para SC-200 basta con recordar:

Cross-domain/untrusted scenario → HTTPS + certificates

1.3.3.7 Validación y troubleshooting

Los comandos más útiles son:

`wecutil gr <SubscriptionName>`

para consultar:

runtime status

y:

`wecutil gs <SubscriptionName>`

para consultar:

subscription configuration

Por tanto:

`gr = runtime status`

`gs = subscription configuration`

También debe comprobarse:

ForwardedEvents

en el WEC.

1.3.4 Plan and configure Syslog via AMA and Common Event Format (CEF) via AMA connectors

Microsoft Sentinel dispone de dos conectores AMA para fuentes Linux y dispositivos que envían logs mediante Syslog:

Conector	**Uso**	**Tabla**
Syslog via AMA	Syslog estándar	`Syslog`
Common Event Format (CEF) via AMA	Dispositivos que generan CEF sobre Syslog	`CommonSecurityLog`

La regla fundamental para SC-200 es:

Syslog → `Syslog`

CEF → `CommonSecurityLog`

1.3.4.1 Arquitectura

AMA puede instalarse directamente en una máquina Linux que genera Syslog o, más habitualmente para dispositivos de red, sobre un:

Linux log forwarder

El flujo típico es:

Firewall / IDS / Linux / Appliance

⇓

Syslog TCP/UDP 514

⇓

Linux forwarder: rsyslog o syslog-ng

⇓

AMA + DCR

⇓

Microsoft Sentinel

El forwarder puede estar:

- en Azure;
- on-premises;
- en otro cloud.

1.3.4.2 Configuración

Desde:

Microsoft Sentinel → Configuration → Data connectors

se abre:

Syslog via AMA

o:

Common Event Format (CEF) via AMA

y se crea una:

Data Collection Rule (DCR)

En la DCR se seleccionan principalmente:

- Linux machine / log forwarder;
- **Syslog facilities**;
- **minimum log severity**.

Ejemplos de facilities:

- `auth`;
- `authpriv`;
- `daemon`;
- `kern`;
- `local0--local7`.

Por ejemplo:

```
authpriv + Warning
```

significa recopilar eventos de esa facility con severidad Warning y niveles más críticos.

1.3.4.3 CEF

CEF utiliza:

Syslog como mecanismo de transporte

pero añade un formato estructurado:

```
CEF:Version|Device Vendor|Device Product|
Device Version|Signature ID|Name|Severity|Extension
```

Por tanto:

CEF no es un protocolo de transporte distinto de Syslog

El dispositivo envía mensajes CEF mediante Syslog y Sentinel los normaliza en:

```
CommonSecurityLog
```

1.3.4.4 Evitar duplicados

Debe evitarse configurar simultáneamente Syslog y CEF para ingerir los mismos mensajes/facilities.

1.3.4.5 Escenarios típicos de examen

Escenario 1: servidor Linux genera logs estándar.

Syslog via AMA → `Syslog`

Escenario 2: firewall soporta Common Event Format.

CEF via AMA → `CommonSecurityLog`

Escenario 3: múltiples firewalls no pueden ejecutar AMA.

Linux log forwarder + AMA

Escenario 5: aparecen los mismos eventos en `Syslog` y `CommonSecurityLog`.

Comprobar solapamiento entre las DCR de Syslog y CEF.

1.3.5 Configure collection of Azure activity logs by using Azure Policy and resource diagnostic settings

Para SC-200 deben distinguirse:

Azure Activity Log = operaciones sobre recursos Azure

Resource logs = operaciones internas de cada recurso

Por ejemplo:

Crear/eliminar una VM → Activity Log

Acceso a un Key Vault → Resource log

1.3.5.1 Azure Activity Log

El Activity Log registra eventos del:

Azure control plane

y se recopila automáticamente por Azure.
Sin embargo, para analizarlo en Microsoft Sentinel debe exportarse al:

Log Analytics workspace

mediante un:

Diagnostic setting

Los eventos aparecen en:

`AzureActivity`

El Activity Log se conserva nativamente durante:

90 días

y el envío a Log Analytics permite mayor retención y análisis mediante KQL.

1.3.5.2 Configuración desde Microsoft Sentinel

La solución:

Azure Activity

se instala desde Content Hub.
Después:

Data connectors → Azure Activity → Open connector page

y se selecciona:

Launch Azure Policy Assignment Wizard

El wizard permite definir:

1. **Scope**: subscription que se quiere monitorizar.
2. **Primary Log Analytics workspace**: workspace de Sentinel.
3. Crear la asignación de Azure Policy.

El resultado es:

Azure subscription

⇓

Diagnostic setting

⇓

Log Analytics / Sentinel

⇓

`AzureActivity`

1.3.5.3 Categorías del Activity Log

Entre las principales categorías están:

- **Administrative**;
- **Security**;
- **Service Health**;
- **Resource Health**;
- **Alert**;
- **Recommendation**;
- **Policy**;
- **Autoscale**.

Para análisis de cambios administrativos es especialmente importante:

Administrative

1.3.5.4 Resource diagnostic settings

Los:

Resource logs

no se recopilan automáticamente.
Deben habilitarse mediante:

Diagnostic settings

en cada recurso.
Ruta habitual:

Azure resource → Monitoring → Diagnostic settings

Se seleccionan:

- categorías de logs;
- métricas, si procede;
- destino.

Para Sentinel, el destino habitual es:

Send to Log Analytics workspace

1.3.5.5 Destinos posibles

Un diagnostic setting puede enviar datos a:

- **Log Analytics workspace**;
- **Storage Account**;
- **Event Hub**.

Para detección y análisis con Sentinel:

Log Analytics workspace

1.3.5.6 Tabla de destino

Dependiendo del servicio, los resource logs pueden almacenarse en:

`AzureDiagnostics`

o en:

resource-specific tables

El Activity Log, en cambio, utiliza:

`AzureActivity`

1.3.5.7 Azure Policy

Configurar manualmente diagnostic settings es viable para pocos recursos.
Para cientos de recursos debe utilizarse:

Azure Policy

Microsoft proporciona políticas integradas con efecto:

DeployIfNotExists

que crean automáticamente diagnostic settings cuando no existen.
Por tanto:

Diagnostic setting individual → configuración manual

Muchos recursos → Azure Policy

1.3.5.8 Recursos nuevos y existentes

Una política:

DeployIfNotExists

puede configurar automáticamente nuevos recursos.
Para aplicar la configuración también a recursos:

ya existentes

debe utilizarse una:

Remediation task

Por tanto:

Existing noncompliant resources → Remediation task

1.3.5.9 Managed Identity

Una asignación de Azure Policy que utiliza:

DeployIfNotExists

requiere una:

Managed Identity

con permisos suficientes para crear los diagnostic settings.
Ejemplos de roles válidos:

- **Monitoring Contributor**;
- **Log Analytics Contributor**.

1.3.5.10 Category groups

Las políticas modernas de diagnostic settings pueden utilizar grupos de categorías:

- `allLogs`: todos los logs disponibles;
- `audit`: logs de auditoría.

Esto permite que una política incorpore automáticamente nuevas categorías añadidas posteriormente al grupo.

1.3.5.11 Escenarios típicos de examen

Escenario 1: se quiere detectar quién creó, modificó o eliminó recursos Azure.

Azure Activity Log → `AzureActivity`

Escenario 2: se necesitan logs internos de Azure Key Vault.

Resource diagnostic settings

Escenario 3: cientos de recursos deben enviar sus resource logs a Sentinel.

Azure Policy + DeployIfNotExists

Escenario 4: la política ya está asignada pero existen recursos antiguos sin diagnostic settings.

Create remediation task

Escenario 5: se quieren enviar todos los logs disponibles de un recurso.

Category group = `allLogs`

1.3.6 Ingest threat indicators into Microsoft Sentinel

Microsoft Sentinel permite ingerir **Threat Intelligence (TI)** procedente de Microsoft, feeds externos y Threat Intelligence Platforms (TIP).

Para SC-200 deben conocerse principalmente estas vías:

Origen	**Método**
Microsoft Defender Threat Intelligence	Defender Threat Intelligence connector
Feed STIX/TAXII	Threat Intelligence – TAXII connector
TIP o aplicación propia	Threat Intelligence Upload API
Indicador puntual	Creación manual desde Intel management

1.3.6.1 Threat Intelligence – TAXII

Si el proveedor ofrece:

STIX + TAXII

debe utilizarse:

Threat Intelligence – TAXII

Sentinel actúa como cliente TAXII y obtiene información desde servidores:

TAXII 2.0 o 2.1

Para configurar el conector se necesitan principalmente:

- **API Root URL**;
- **Collection ID**;
- credenciales, si el servidor TAXII las requiere.

Por tanto:

Proveedor STIX/TAXII → TAXII connector

1.3.6.2 STIX vs. TAXII

No deben confundirse:

STIX = formato/modelo de Threat Intelligence

TAXII = protocolo utilizado para intercambiarla

Esta diferencia es especialmente preguntable.

1.3.6.3 Defender Threat Intelligence

Microsoft proporciona también:

Defender Threat Intelligence data connector

para incorporar indicadores de Microsoft directamente al workspace.
Se configura desde:

Microsoft Sentinel → Configuration → Data connectors

seleccionando el conector Defender Threat Intelligence y:

Connect

1.3.6.4 Creación manual

Para un indicador u objeto TI individual puede utilizarse:

Threat intelligence → Intel management → Add new

y crear un:

TI object

manualmente.
Es apropiado para:

- indicadores obtenidos durante una investigación;
- IOC puntuales;
- información que todavía no procede de un feed automatizado.

1.3.6.5 Ingestion rules

Sentinel permite aplicar:

Threat Intelligence ingestion rules

sobre objetos entrantes.
Pueden utilizarse para:

- filtrar información;
- añadir tags;
- modificar propiedades;
- extender la fecha **Valid until**.

Las reglas se ejecutan según:

Order

de menor a mayor.
Su objetivo es:

reducir ruido y mejorar la calidad de los feeds

1.3.6.6 Uso posterior

Los indicadores ingeridos pueden compararse con los eventos del entorno mediante reglas:

TI map...

1.3.7 Create custom log tables in the workspace to store ingested data

Cuando una fuente genera datos cuyo esquema no corresponde con una tabla estándar, pueden almacenarse en una:

Custom table

del Log Analytics workspace utilizado por Microsoft Sentinel.

1.3.7.1 Creación

Ruta principal:

Log Analytics workspace → Tables → Create → New custom log (DCR-based)

Durante la creación se define:

1. nombre de la tabla;
2. **table plan**;
3. esquema/columnas;
4. Data Collection Rule;
5. destino de los datos.

1.3.7.2 Nombre

Las tablas personalizadas deben terminar en:

`_CL`

Por ejemplo:

`FirewallCustom_CL`

Si la tabla se crea desde el portal:

Azure añade automáticamente el sufijo `_CL`.

1.3.7.3 Esquema

Cada tabla tiene un esquema formado por:

column name + data type

Entre los tipos habituales están:

- `string`;
- `int`;
- `long`;
- `real`;
- `boolean`;
- `datetime`;
- `dynamic`.

Toda tabla del Log Analytics workspace debe disponer de:

`TimeGenerated`

de tipo:

`datetime`

Si no se proporciona, Azure Monitor puede incorporarlo mediante la transformación de la DCR.

1.3.7.4 Table plan

Al crear la tabla puede seleccionarse:

- **Analytics**;
- **Basic**;
- **Auxiliary / Lake**.

La selección depende de cómo se utilizarán los datos.
Para datos que deben participar en:

detecciones y análisis operativo frecuente

debe utilizarse normalmente:

Analytics

Los planes Basic o Auxiliary/Lake son apropiados para datos con menor necesidad de análisis en tiempo real.

1.3.7.5 Relación con la DCR

La:

Data Collection Rule

determina cómo los datos entrantes se convierten en registros compatibles con la tabla.
Conceptualmente:

Source data

⇓

DCR

⇓

Transformation KQL

⇓

`CustomTable_CL`

El nombre del:

output stream

de la DCR debe coincidir con la tabla de destino.
Por ejemplo:

```
Custom-FirewallCustom_CL
```

1.3.7.6 Transformation

Si los datos de origen no coinciden exactamente con el esquema de la tabla, la DCR puede aplicar una:

KQL transformation

antes de almacenarlos.
Por ejemplo:

```
source
| project
TimeGenerated = todatetime(timestamp),
SourceIP = tostring(src_ip),
Action = tostring(action)
```

La transformación puede utilizarse para:

- cambiar nombres de campos;
- convertir tipos;
- eliminar columnas;
- filtrar registros;
- calcular nuevos campos.

El resultado final de la transformación debe ser compatible con:

el esquema de la tabla de destino.

1.3.7.7 Logs Ingestion API

Una aplicación externa puede enviar directamente datos a una custom table mediante:

Azure Monitor Logs Ingestion API

El flujo es:

Application

⇓

Logs Ingestion API

⇓

DCR

⇓

Custom table

La tabla debe:

existir antes de enviar los datos.

La DCR define:

- estructura de entrada;
- transformación;
- tabla de destino.

1.3.7.8 Consulta

Una vez ingeridos los datos, la tabla se consulta mediante KQL como cualquier otra tabla:

```
FirewallCustom_CL
| where TimeGenerated > ago(1h)
| summarize count() by Action
```

1.3.7.9 Escenarios típicos de examen

Escenario 1: una aplicación propia genera logs con campos que no corresponden a ninguna tabla estándar.

Crear custom table + DCR

Escenario 2: los nombres y tipos recibidos no coinciden con el esquema de la tabla.

Aplicar KQL transformation en la DCR

Escenario 3: una aplicación externa debe enviar datos directamente mediante REST.

Logs Ingestion API + DCR + custom table

Escenario 4: se crea manualmente una tabla denominada `MyApplication` mediante API/CLI.

Debe denominarse:

`MyApplication_CL`

1.4 Configure detections

1.4.1 Create custom detection rules by using Advanced Hunting in Microsoft Defender XDR

Las **Custom Detection Rules** convierten consultas KQL de Advanced Hunting en detecciones que se ejecutan automáticamente para:

generar alertas y, opcionalmente, ejecutar acciones de respuesta.

El flujo fundamental es:

Advanced Hunting query → Custom Detection → Alert / Response

1.4.1.1 Creación

La forma habitual es:

Hunting → Advanced hunting

1. Crear y ejecutar la consulta KQL.
2. Comprobar que devuelve los resultados esperados.
3. Seleccionar **Create detection rule**.
4. Configurar alerta, frecuencia, entidades y acciones.
5. Definir el scope.
6. Revisar y crear la regla.

También puede crearse directamente desde:

Hunting → Custom detection rules → Create detection rule

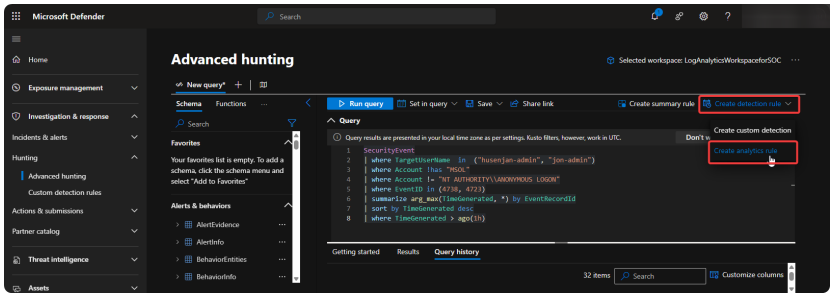


Figure 9: Caption

1.4.1.2 Entity mapping

Las columnas devueltas por la consulta permiten asociar entidades al alert.

Identificadores habituales:

- Device: `DeviceId`, `DeviceName`;
- Account: `AccountObjectId`, `AccountSid`, `AccountUpn`;
- Mailbox: `RecipientEmailAddress`;
- otras entidades: IP, file, process, URL, etc.

Para SC-200: **Si quieres que una entidad aparezca correctamente en la alerta, debes devolver su identificador en la query.**

1.4.1.3 Alert details

Durante la creación se configuran:

- Detection name;
- Alert title;
- Severity;
- Category;
- MITRE ATT&CK tactic;
- technique/sub-technique;
- Description;
- Recommended actions.

El título y la descripción pueden incluir valores dinámicos procedentes de columnas de la consulta.

Por ejemplo:

```
Suspicious PowerShell execution on {{DeviceName}}
```

Pueden utilizarse hasta:

3 columnas dinámicas por campo.

1.4.1.4 Frecuencia

Las frecuencias estándar son:

- **Continuous (NRT)**;
- Every hour;
- Every 3 hours;
- Every 12 hours;
- Every 24 hours.

Para reglas basadas exclusivamente en datos de Microsoft Sentinel también puede utilizarse:

Custom frequency

entre:

5 minutos y 14 días

1.4.1.5 Continuous (NRT)

Continuous (Near Real-Time) permite detectar eventos prácticamente cuando se ingieren.

Debe utilizarse cuando:

se necesita minimizar el tiempo entre evento y alerta.

Pero la consulta debe cumplir restricciones, entre ellas:

- consultar una sola tabla;
- utilizar únicamente operadores soportados;
- no utilizar `join`;
- no utilizar `union`;
- no utilizar `externaldata`.

Por tanto:

Una query compleja con joins no puede ejecutarse como Continuous (NRT).

1.4.1.6 No filtrar innecesariamente por Timestamp

Custom detections ya aplican automáticamente el:

> **lookback**

sobre los datos.
Por ello Microsoft recomienda no añadir filtros adicionales mediante:

```
| where Timestamp > ago(...)
```

salvo que se necesite restringir aún más el periodo analizado.
Las custom detections utilizan además:

> `ingestion_time()`

para tener en cuenta retrasos de ingestión.

1.4.1.7 Rule scope

Las detecciones relacionadas con dispositivos pueden limitarse a:

- **All devices**;
- **Specific device groups**.

La regla:

> **solo consulta y ejecuta acciones sobre los dispositivos incluidos en el scope.**

El usuario que crea o modifica la regla necesita permisos sobre los device groups incluidos.

1.4.1.8 Límite de alertas

Cada ejecución de una Custom Detection Rule puede generar como máximo:

> **150 alerts**

Por tanto, una consulta excesivamente amplia debe ajustarse para evitar alert fatigue.
Microsoft además:

> **agrupa y deduplica eventos repetidos**

para reducir alertas duplicadas cuando existen solapamientos entre ventanas de lookback.

1.4.1.9 Gestión

Las reglas existentes se encuentran en:

Hunting → Custom detection rules

Desde ahí pueden:

- ejecutarse manualmente;
- editarse;
- habilitarse/deshabilitarse;
- eliminarse;
- revisarse ejecuciones anteriores;
- comprobarse alertas y acciones generadas.

1.4.1.10 Custom Detection vs. Analytics Rule

En el Defender portal unificado pueden utilizarse datos Defender y Sentinel.
La diferencia principal es:

Custom Detection Rule → Defender data o Defender + Sentinel

Analytics Rule → datos ingeridos en Microsoft Sentinel

Si una consulta usa datos Defender que no están siendo ingeridos en Sentinel:

debe utilizarse Custom Detection Rule

y no una Sentinel Analytics Rule.

1.4.1.11 Permisos

Para administrar custom detections sobre datos Defender se necesita normalmente:

Security settings (manage)

o un rol equivalente con permisos sobre los productos y datos consultados.
Si la regla utiliza datos de Microsoft Sentinel:

Microsoft Sentinel Contributor

es necesario sobre el workspace correspondiente.

1.4.1.12 Escenarios típicos de examen

Escenario 1: una query de Advanced Hunting detecta PowerShell sospechoso y debe generar automáticamente una alerta.

Create detection rule

Escenario 2: la detección debe identificar correctamente el dispositivo afectado.

Incluir `DeviceId` en los resultados.

Escenario 3: la detección debe aislar automáticamente el endpoint.

Custom Detection + Isolate device + `DeviceId`

Escenario 4: se necesita detección near real-time pero la consulta utiliza `join`.

No puede utilizar Continuous (NRT) sin rediseñar la consulta.

Escenario 5: la regla debe ejecutarse únicamente sobre servidores críticos.

Scope = specific device group

Escenario 6: una consulta genera cientos de resultados normales en cada ejecución.

Ajustar la query antes de convertirla en detección; máximo 150 alertas por ejecución.

1.4.2 Manage custom detection rules in Microsoft Defender XDR

Las reglas existentes se administran desde:

Hunting → Custom detection rules

Desde esta página pueden:

- visualizarse las reglas existentes;
- buscarse por nombre o Rule ID;
- filtrarse;
- habilitarse o deshabilitarse;
- editarse;
- ejecutarse manualmente;
- eliminarse;
- revisarse alertas y acciones generadas.

1.4.2.1 Información de ejecución

La lista de reglas muestra principalmente:

- **Last run**: última ejecución;
- **Last run status**: si la ejecución fue correcta;
- **Next run**: próxima ejecución programada;
- **Status**: On/Off.

En organizaciones con varios workspaces de Sentinel también pueden utilizarse:

Workspace ID / Workspace name

para filtrar las reglas.

1.4.2.2 Rule details

Seleccionando una regla se abre su página de detalle.
Desde ella pueden realizarse:

- **Run**: ejecuta inmediatamente la regla. Run manual también reinicia el intervalo hasta la siguiente ejecución programada.
- **Edit**: abre el wizard completo de la regla y permite modificar sus atributos, como frecuencia, scope, actions...
- **Modify query**: abre directamente la consulta en Advanced Hunting para modificar el KQL.
- **Turn on / Turn off**: para habilitar y deshabilitar la regla. No se elemine, pero no se ejecuta.
- **Delete**: deshabilita y elimina permanentemente la regla.

1.4.2.3 Triggered alerts

En:

Rule details → Triggered alerts

pueden consultarse las alertas generadas por la regla.
Desde cada alerta puede:

- cambiarse el estado;
- establecerse la clasificación;
- marcarse como true positive o false positive;
- vincularse a un incidente;
- ejecutar de nuevo en Advanced Hunting la consulta que produjo la alerta.

1.4.2.4 Reglas de Sentinel en el portal unificado

Cuando un workspace de Microsoft Sentinel está conectado al Microsoft Defender portal:

> **la página Custom detection rules también puede mostrar Analytics Rules de Sentinel.**

En este caso pueden consultarse y administrarse desde una misma experiencia. Sin embargo, determinadas acciones son específicas de las custom detections. Por ejemplo:

> **Run manual**

y:

> **Triggered actions**

son funcionalidades propias de Custom Detection Rules.

1.4.2.5 Escenarios típicos de examen

Escenario 1: una regla está generando demasiados falsos positivos pero se quiere conservar su configuración.

> **Turn off + Modify query**

Escenario 2: se quiere probar inmediatamente una regla sin esperar a la siguiente ejecución.

> **Run**

Recordar que:

> **se reinicia el intervalo de la próxima ejecución.**

Escenario 3: se quiere investigar por qué una regla generó una alerta.

> **Triggered alerts → Run query in Advanced Hunting**

Escenario 4: se quiere comprobar si la regla aisló realmente un dispositivo.

> **Triggered actions**

Escenario 5: se quiere modificar únicamente el KQL.

> **Modify query**

Escenario 6: se quiere cambiar frecuencia, acciones automáticas y scope.

> **Edit**

Escenario 7: una regla periódica es compatible con near real-time.

> **Migrate now → Continuous (NRT)**

1.4.3 Configure and manage analytics rules in Microsoft Sentinel SIEM, including scheduled, near-real time (NRT), threat intelligence, and machine learning

Las **Analytics Rules** de Microsoft Sentinel analizan los datos ingeridos para generar:

Alerts → Incidents

Se administran desde:

Microsoft Sentinel → Configuration → Analytics

Las pestañas principales son:

- **Active rules**;
- **Rule templates**;
- **Anomalies**.

Microsoft recomienda utilizar, cuando exista, una:

rule template

procedente de Content Hub y adaptarla al entorno.

1.4.3.1 Tipos principales

Para SC-200 deben distinguirse:

Tipo	Uso
Scheduled	Ejecuta periódicamente una consulta KQL sobre un periodo de datos.
NRT	Ejecuta la detección cada minuto para reducir la latencia.
Threat Intelligence	Compara indicadores de amenaza con eventos ingeridos.
Machine Learning	Utiliza modelos Microsoft para detectar comportamientos o correlaciones anómalas.

1.4.3.2 Scheduled analytics rules

Son el tipo más habitual.

Funcionan mediante:

KQL query + schedule + lookback + threshold

Dos parámetros fundamentales son:

- **Run query every**: frecuencia de ejecución.

- **Lookup data from the last**: periodo de datos analizado.

Ambos admiten valores entre:

5 minutos y 14 días

Debe cumplirse:

Query frequency ≤ Lookback period

Por ejemplo:

Run every = 1 hour

Lookback = 2 hours

es válido.
Pero:

Run every = 2 hours

Lookback = 1 hour

no es válido porque existirían huecos sin analizar.

1.4.3.3 Trigger threshold

La regla puede generar una alerta cuando el número de resultados de la consulta cumple un umbral.
Por ejemplo:

Generate alert when number of query results > 5

Por tanto:

Scheduled rule puede utilizar threshold

1.4.3.4 Ingestion delay

Las Scheduled Analytics Rules se ejecutan con un retraso incorporado de:

5 minutos

para compensar retrasos entre la generación del evento y su ingestión en Sentinel.
Esto evita perder eventos debido a:

ingestion latency

1.4.3.5 Alert enrichment

En una Scheduled o NRT rule pueden configurarse:

- **Entity mappings**;
- **Custom details**;
- **Alert details**.

Entity mappings convierten columnas KQL en entidades como:

- Account;
- Host;
- IP;
- URL;
- File;
- Process.

Ejemplo:

`IPAddress` → IP entity

Esto mejora la correlación e investigación posterior.

1.4.3.6 Alert grouping

Puede elegirse:

- crear una única alerta con todos los eventos;
- crear una alerta por cada evento.

También pueden configurarse los criterios para agrupar:

alerts into incidents

reduciendo el número de incidentes independientes generados por una misma amenaza.

1.4.3.7 Event grouping vs. Incident grouping

No deben confundirse:

Event grouping

determina cómo los resultados de una ejecución se convierten en alertas.
Mientras que:

Alert grouping

determina cómo esas alertas se agrupan posteriormente en incidentes.

1.4.3.8 NRT analytics rules

Las:

Near-real-time (NRT) rules

están diseñadas para detección rápida.
Se ejecutan automáticamente:

cada 1 minuto

y analizan aproximadamente:

el último minuto de datos

Por tanto:

NRT = 1-minute frequency + 1-minute lookback

Estos parámetros:

no son configurables.

1.4.3.9 NRT y latencia

A diferencia de las Scheduled Rules, las NRT:

utilizan el momento de ingestión del evento

y trabajan con un retraso aproximado de:

2 minutos

para ofrecer detección prácticamente en tiempo real.

1.4.3.10 Threat Intelligence analytics rules

Las reglas Threat Intelligence permiten comparar:

Threat Indicators

con:

eventos procedentes de data connectors

1.4.3.11 Machine Learning analytics rules

Sentinel dispone de reglas especializadas que utilizan algoritmos de:

Machine Learning

desarrollados por Microsoft.
Dos conceptos especialmente importantes son:

- **ML Behavior Analytics**;
- **Fusion**.

1.4.3.12 ML Behavior Analytics

Las reglas:

Machine Learning Behavior Analytics

utilizan modelos Microsoft para identificar comportamientos anómalos.
Actualmente están en:

Preview

y no permiten personalizar la lógica ML interna.
Entre sus casos de uso se encuentran:

comportamientos anómalos de inicio de sesión SSH y RDP

utilizando información como:

- IP;
- geolocalización;
- historial del usuario.

Para SC-200:

ML Behavior Analytics = modelos Microsoft predefinidos, no KQL personalizado

1.4.3.13 Fusion

Fusion utiliza machine learning para correlacionar:

múltiples alertas y actividades de baja fidelidad

procedentes de diferentes productos y detectar:

multistage attacks

El resultado son normalmente incidentes:

- de bajo volumen;
- alta fidelidad;
- alta severidad.

1.4.3.14 Cambio actual de Fusion

En workspaces incorporados al:

Microsoft Defender portal

Fusion está actualmente:

deshabilitado

porque su función es sustituida por:

Microsoft Defender XDR correlation engine

Este cambio es importante para no responder utilizando únicamente documentación antigua.

1.4.3.15 Anomaly rules

Aunque el objetivo menciona Machine Learning, conviene reconocer también:

Anomaly rules

Estas reglas utilizan ML para aprender una:

behavioral baseline

y detectar desviaciones.
Una anomalía:

no implica necesariamente una amenaza

por lo que las Anomaly Rules:

no generan directamente alertas

Los resultados se almacenan en:

`Anomalies`

y pueden utilizarse posteriormente en:

- detecciones;
- hunting;
- investigación.

1.4.3.16 Required data sources

Antes de crear una regla desde una template, Sentinel comprueba:

Required data sources

Si el origen necesario:

no está conectado o no está ingiriendo datos

la regla puede no poder crearse o no funcionar correctamente.
Por tanto:

Rule template sin datos requeridos → comprobar data connector

1.4.4 Analyze attack vector coverage by using the MITRE ATT&CK matrix

Microsoft Sentinel utiliza el framework:

MITRE ATT&CK

para visualizar qué partes del ciclo de ataque están cubiertas por las detecciones configuradas en el entorno.
La ruta actual es:

Microsoft Sentinel → Threat management → MITRE ATT&CK

1.4.4.1 Tactics, techniques y sub-techniques

La matriz organiza el comportamiento de un atacante en:

Tactic → Technique → Sub-technique

Por ejemplo:

Credential Access

⇓

Valid Accounts (T1078)

⇓

Cloud Accounts (T1078.004)

Conceptualmente:

- **Tactic**: objetivo que intenta conseguir el atacante.
- **Technique**: cómo intenta conseguirlo.
- **Sub-technique**: variante más específica de una técnica.

1.4.4.2 Active coverage vs. Simulated coverage

Ésta es la distinción más importante para el examen.

Active coverage

muestra la protección proporcionada por:

detecciones actualmente habilitadas

Mientras que:

Simulated coverage

muestra la cobertura que podría alcanzarse si se habilitasen:

detecciones disponibles pero todavía no configuradas.

Por tanto:

Active = lo que tengo

Simulated = lo que podría tener

1.4.4.3 Identificar coverage gaps

El principal uso de la matriz consiste en detectar:

técnicas con poca o ninguna detección activa

y compararlas con las detecciones disponibles.
Ejemplo:

Technique T1078: 0 active detections

pero:

3 detections available

indica un:

coverage gap

que potencialmente puede corregirse habilitando contenido adicional.

1.4.5 Configure anomalies in Microsoft Sentinel

Microsoft Sentinel incluye:

customizable anomaly rules

basadas en modelos estadísticos y de Machine Learning proporcionados por Microsoft.

Se administran desde:

Microsoft Sentinel → Configuration → Analytics → Anomalies

Las reglas de anomalías integradas están:

habilitadas por defecto

y generan registros en:

`Anomalies`

Una anomalía representa comportamiento inusual:

no implica necesariamente actividad maliciosa.

1.4.5.1 Propiedades de una anomaly rule

Al seleccionar una regla pueden consultarse:

- Description;
- MITRE ATT&CK tactics and techniques;
- Data sources;
- **Parameters**;
- **Threshold**;
- Rule frequency;
- Rule status;
- Anomaly version.

El:

Threshold

determina cuánto debe desviarse un evento del comportamiento esperado antes de generar una anomalía.

En general:

Threshold demasiado bajo → demasiadas anomalías

1.4.5.2 Built-in rules

Las reglas integradas proporcionadas por Microsoft:

no pueden editarse directamente

Para modificar una debe:

Duplicate → Edit customized rule

La copia aparece inicialmente:

- **Disabled**;
- en modo **Flighting**;
- identificada mediante **FLGT**.

1.4.5.3 Tuning

En la copia personalizada pueden modificarse:

- threshold;
- parámetros específicos del modelo.

Los parámetros disponibles:

dependen del algoritmo de anomalía concreto.

El panel:

Results preview

permite comprobar cómo afectarían los cambios antes de poner la regla en producción.

1.4.5.4 Production vs. Flighting

Existen dos modos fundamentales:

Modo	Uso
Production	Regla utilizada operativamente.
Flighting	Regla de prueba para evaluar nuevos parámetros sin sustituir inmediatamente la configuración de producción.

El flujo recomendado es:

Built-in rule = Production

⇓

Duplicate

⇓

Customized rule = Flighting

⇓

Comparar resultados

⇓

Customized rule → Production

Cuando la copia personalizada pasa a Production:

la regla original cambia automáticamente a Flighting

porque no pueden existir:

dos versiones de la misma anomaly rule en Production simultáneamente.

1.4.5.5 UEBA vs. ML anomalies

También deben distinguirse:

UEBA → quién se está comportando de forma inusual

frente a:

ML anomaly rules → qué actividad es inusual

Ambos tipos pueden escribir resultados en:

`Anomalies`

1.4.5.6 Escenarios típicos de examen

Escenario 1: una anomaly rule integrada genera demasiados resultados.

Duplicate → ajustar Threshold/Parameters

Escenario 2: se quiere probar una configuración nueva sin sustituir la regla actual.

Flighting

Escenario 3: la configuración personalizada ya ofrece mejores resultados.

Cambiar la customized rule a Production

La original pasará automáticamente a Flighting.

Escenario 4: se quiere conocer por qué se produjo una anomalía.

Consultar `AnomalyReasons` en la tabla `Anomalies`